



Planta San Luis Potosí



## SGSI -Equipo 3

Alvarez Aquino Enrique - 177071

Arellano Wratny Elisa Alejandra - 177339

López Alemán Emiliano - 182883

Portales Pérez Luis Gabriel - 174278

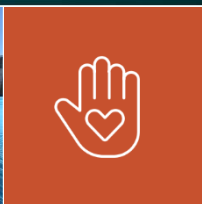
Rodríguez Rivera José Vicente - 179954



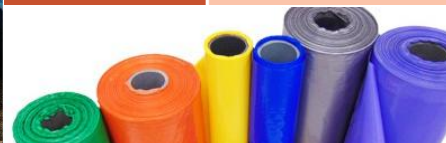
GHG  
EMISSIONS  
& CLIMATE  
CHANGE



MATERIALS  
MANAGEMENT  
& INNOVATION



COMMUNITY  
IMPACT



MATERIALS INNOVATION:  
NEW PRODUCT  
LAUNCHES



## Tabla de Contenido

|                                                                   |    |
|-------------------------------------------------------------------|----|
| Acerca .....                                                      | 4  |
| Misión .....                                                      | 5  |
| Visión .....                                                      | 5  |
| Valores .....                                                     | 5  |
| Lo que hacemos .....                                              | 6  |
| Organización .....                                                | 6  |
| 1. Alcance .....                                                  | 8  |
| 2. Referencias normativas .....                                   | 9  |
| 3. Términos y definiciones .....                                  | 11 |
| 3.1 Glosario de términos. ....                                    | 11 |
| 4. Contexto de la organización .....                              | 13 |
| 4.1 Activos internos.....                                         | 13 |
| 4.2 Activos externos .....                                        | 15 |
| 5. Liderazgo .....                                                | 17 |
| 5.1 Política General de Seguridad ProAmpac.....                   | 17 |
| 5.1.1 Objetivo .....                                              | 17 |
| 5.1.2 Alcance .....                                               | 17 |
| 5.1.3 Compromiso de la Dirección .....                            | 18 |
| 5.2 Políticas Funcionales.....                                    | 19 |
| 5.2.1 Gestión de acceso.....                                      | 19 |
| 5.2.2 Implementación de actualizaciones.....                      | 19 |
| 5.2.3 Recuperación ante desastres.....                            | 19 |
| 5.2.4 Gestión de respaldos de información.....                    | 19 |
| 5.2.5 Gestión de incidentes de seguridad.....                     | 19 |
| 5.2.6 Seguridad del correo electrónico corporativo.....           | 20 |
| 5.2.7 Gestión de dispositivos móviles y remotos.....              | 20 |
| 5.2.8 Clasificación y manejo de la información.....               | 20 |
| 5.2.9 Seguridad física y ambiental.....                           | 20 |
| 5.2.10 Capacitación y concientización en seguridad.....           | 21 |
| 5.2.11 Gestión y custodia de contratos con clientes. ....         | 21 |
| 5.2.12 Seguridad y control de dispositivos de computo.....        | 21 |
| 5.2.13 Almacenamiento seguro en OneDrive y SharePoint.....        | 21 |
| 5.2.14 Fórmulas para creación de productos.....                   | 22 |
| 5.2.15 Documentación de procesos de manufactura.....              | 22 |
| 5.2.16 Reportes de auditorías.....                                | 22 |
| 5.2.17 Seguridad y control de acceso del sistema ERP (M3).....    | 22 |
| 5.2.18 Acceso remoto seguro mediante VPN Zscaler.....             | 23 |
| 5.2.19 Gestión segura de Switches de red corporativa.....         | 23 |
| 5.2.20 Seguridad perimetral mediante Firewalls Corporativos.....  | 23 |
| 5.3 Matriz RACI.....                                              | 24 |
| 6. Planificación.....                                             | 26 |
| 6.1 Planificación de riesgos. ....                                | 26 |
| 6.1.1 Accesos no autorizados a sistemas críticos..                | 26 |
| 6.1.2 Vulnerabilidades por falta de actualizaciones.....          | 26 |
| 6.1.3 Pérdida de información por desastres o fallos críticos..... | 26 |





ProActive  
Sustainability



ProActive  
Safety Management

✓ PREPARE. ✓ PROMOTE. ✓ PROTECT.

|                                                                                                      |    |
|------------------------------------------------------------------------------------------------------|----|
| 6.1.4 Corrupción o pérdida de respaldos .....                                                        | 27 |
| 6.1.5 Respuesta tardía ante incidentes de seguridad .....                                            | 27 |
| 6.1.6 Ataques de phishing o malware vía correo electrónico .....                                     | 27 |
| 6.1.7 Compromiso de dispositivos remotos o móviles.....                                              | 27 |
| 6.1.8 Divulgación indebida de información confidencial. ....                                         | 27 |
| 6.1.9 Intrusión física o daño ambiental a infraestructura.....                                       | 28 |
| 6.1.10 Falta de cultura organizacional en seguridad. ....                                            | 28 |
| 6.1.11 Fuga o acceso no autorizado a información contractual de<br>clientes.....                     | 28 |
| 6.1.12 Exposición de datos por robo o pérdida de equipos Dell Latitude<br>/ Optiplex.....            | 28 |
| 6.1.13 Exfiltración de datos mediante enlaces de compartición pública<br>en OneDrive/SharePoint..... | 29 |
| 6.1.14 Exposición o robo de fórmulas de productos confidenciales...29                                |    |
| 6.1.15 Alteración no autorizada de documentación de procesos de<br>manufactura.....                  | 29 |
| 6.1.16 Divulgación o manipulación indebida de reportes de<br>auditoría.....                          | 30 |
| 6.1.17 Alteración o robo de datos en el Sistema ERP (M3) .....                                       | 30 |
| 6.1.18 Acceso remoto no autorizado a través de la VPN (ZSCALER) ...30                                |    |
| 6.1.19 Interrupción o compromiso de red interna vía Switches (CISCO<br>/Fortinet) .....              | 30 |
| 6.1.20 Intrusión perimetral por brechas en el Firewall (Fortigate) .....                             | 31 |
| 6.2 Matriz de Riesgo .....                                                                           | 31 |
| 7. Soporte .....                                                                                     | 33 |
| Presentación .....                                                                                   | 42 |
| 8. Operación .....                                                                                   | 48 |
| Gestión de acceso .....                                                                              | 48 |
| 8.1 Fase de planeación.....                                                                          | 48 |
| 8.1.1 Evidencia documental de controles administrativos .....                                        | 48 |
| 8.2 Fase acción.....                                                                                 | 52 |
| 8.3 Fase verificación .....                                                                          | 52 |
| 8.3.1 Verificación documental de cumplimiento .....                                                  | 53 |
| 8.4 Fase actuación .....                                                                             | 53 |
| 9. Evaluación de desempeño .....                                                                     | 55 |
| 10. Mejora.....                                                                                      | 57 |
| 10.1 Política vulnerada .....                                                                        | 57 |
| 10.2 Riesgo asociado a la política .....                                                             | 57 |
| 10.3 Descripción de la amenaza materializada .....                                                   | 57 |
| 10.4 Análisis de los hechos.....                                                                     | 58 |
| 10.5 Campaña de prevención - Acceso no autorizado a sistemas críticos.....                           | 61 |

## Acerca

ProAmpac es una empresa global líder en empaques flexibles, con una amplia y completa oferta de productos. Ofrecen soluciones de empaque innovadoras, un servicio al cliente de clase mundial y desarrollos premiados, dirigidos a un mercado global diverso. En agosto se cumple una década de crecimiento extraordinario, innovación y trabajo en equipo desde el inicio de la trayectoria de ProAmpac. Desde sus orígenes hasta su presencia global actual, su historia se ha construido sobre resiliencia, colaboración y éxito compartido.

ProAmpac impulsa el futuro del empaque flexible al redefinir la innovación a través de la colaboración, tanto dentro de su organización como con sus clientes y proveedores. Conecta a propietarios de marcas y expertos en empaque para generar nuevas ideas, acelerar el desarrollo de tecnologías avanzadas y mejorar la velocidad de lanzamiento al mercado, la personalización de empaques y la diferenciación para el consumidor.

Se caracteriza por su amplia experiencia fundamentada en valores compartidos, heredados de sus empresas de origen y fortalecidos mediante adquisiciones estratégicas. En conjunto, son una organización más sólida, ágil y con una mayor presencia geográfica.

**ProAmpac** *Celebrating more than 50 years of Excellence & Innovation*

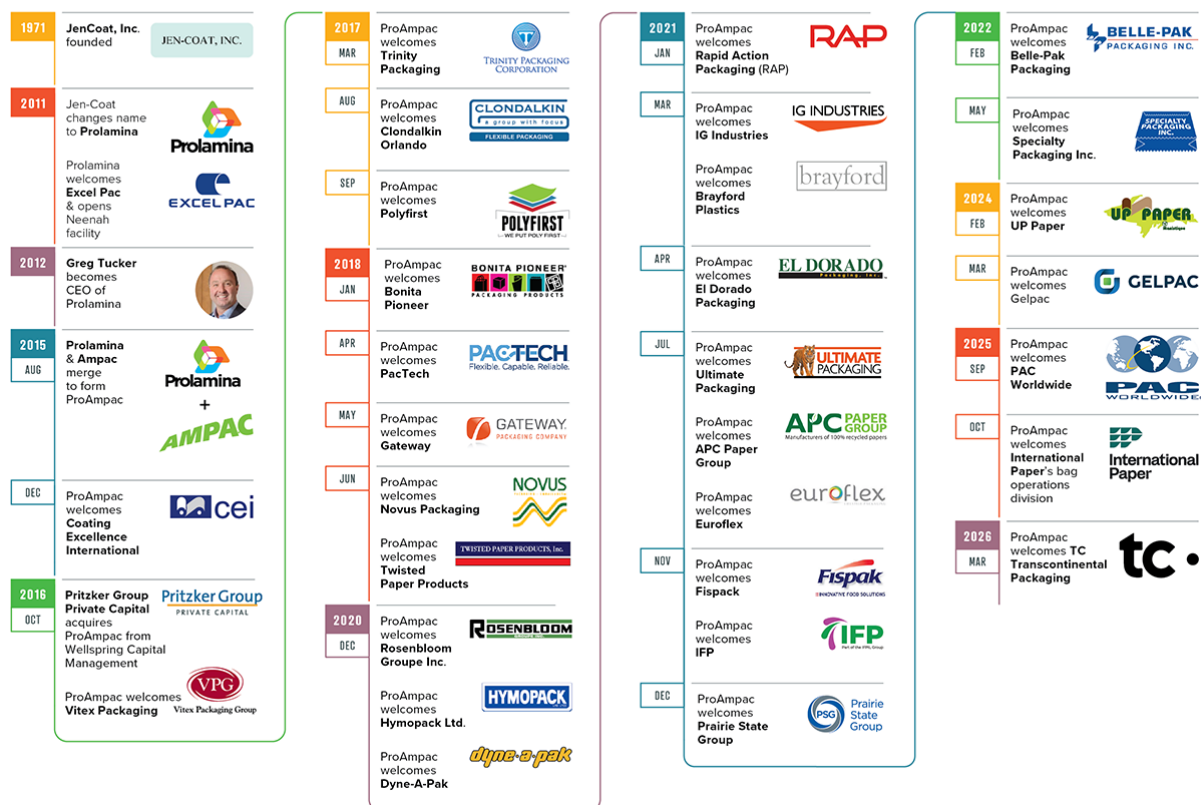


Ilustración 1 Historia de ProAmpac

ProAmpac es miembro de PPC, una firma enfocada en empresas del mercado medio con sede en Norteamérica, con presencia en los sectores de productos manufacturados y servicios. Su estructura de capital diferenciada y de largo plazo permite una toma de decisiones eficiente, gran flexibilidad en la estructuración de transacciones y en el horizonte de inversión, así como una adecuada alineación con todos los grupos de interés.

PPC desarrolla empresas con una visión de largo plazo y es un socio estratégico ideal para compañías de propiedad familiar y emprendedora. Además, PPC es signataria de los Principios para la Inversión Responsable (PRI) de las Naciones Unidas.

## Misión

Proveer soluciones de empaque flexible innovadoras y sostenibles, generando valor para clientes globales mediante tecnología avanzada, colaboración y excelencia operativa.

## Visión

Ser líder global en soluciones de empaque flexible, impulsando la innovación, la sostenibilidad y la diferenciación en el mercado.

## Valores

**Integridad:** Estamos comprometidos a hacer lo correcto por nuestros clientes y nuestros colegas. Compartimos un respeto común por la ética, la comunicación y la responsabilidad.

**Intensidad:** Superamos activamente cada límite para lograr objetivos de beneficio mutuo. Compartimos una pasión por el trabajo arduo, permitiendo que tanto los éxitos como los desafíos renueven nuestra determinación.

**Involucramiento:** Somos un solo equipo de colaboradores capacitados, dedicados a alcanzar un éxito común. Buscamos oportunidades para combinar nuestra experiencia y talento con el fin de generar un mayor impacto global.

**Impacto:** Aprovechamos oportunidades que superar nuestros compromisos, generando un efecto significativo. Lideramos con valentía hacia un crecimiento que impacta nuestras comunidades, el medio ambiente y el mundo.

## Lo que hacemos:

|                                                                                                                                      |                                                                                                                                    |                                                                                                                      |                                                                                                                       |
|--------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------|
| <br>EXTRUSIÓN Y LAMINACIÓN Y RECUBRIMIENTO ADHESIVO | <br>EXTRUSIÓN DE PELÍCULA SOPLADA                 | <br>PERFORACIÓN Y RAYADO           | <br>FABRICACIÓN DE PAPEL RECICLADO |
| <br>TAPAS                                           | <br>ETIQUETAS SENSIBLES A LA PRESIÓN              | <br>BOLSAS PREFABRICADAS           | <br>BOLSAS DE FIBRA                |
| <br>BOLSAS TEJIDAS, DE TRABAJO PESADO Y MULTICAPA   | <br>IMPRESIÓN HD FLEXO, ROTOGRABADO, UV Y DIGITAL | <br>ANÁLISIS, DISEÑO Y PROTOTIPADO | <br>GRÁFICOS INTERNOS              |

Ilustración 2 Material que desarrollamos

## Organización

### ORGANIGRAMA LIDERAZGO PLANTA SLP

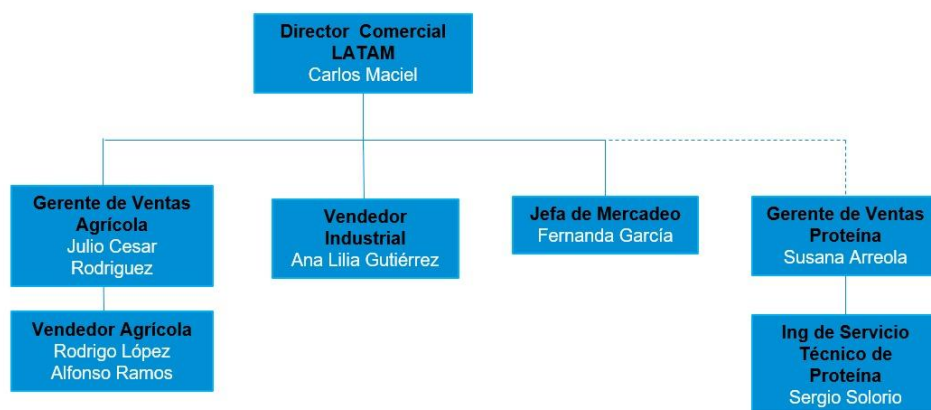


Ilustración 3 Organigrama San Luis Potosí

## ORGANIGRAMA LIDERAZGO Planta SLP

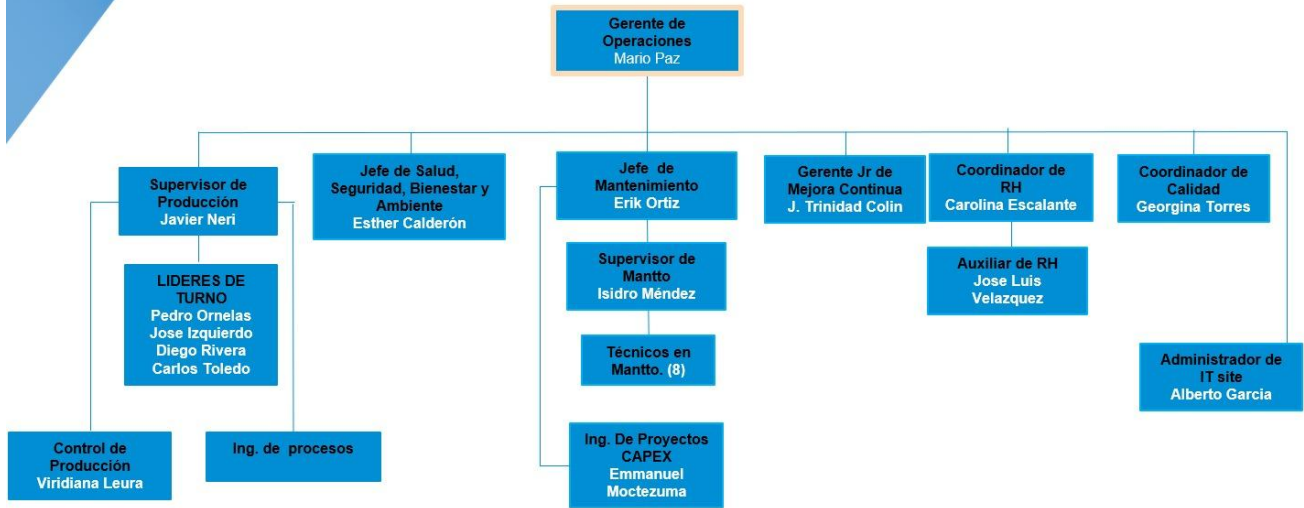


Ilustración 5 Organización Departamental San Luis Potosí, SLP

SLP-RH-FO-002A

## ORGANIGRAMA LIDERAZGO PLANTA SLP

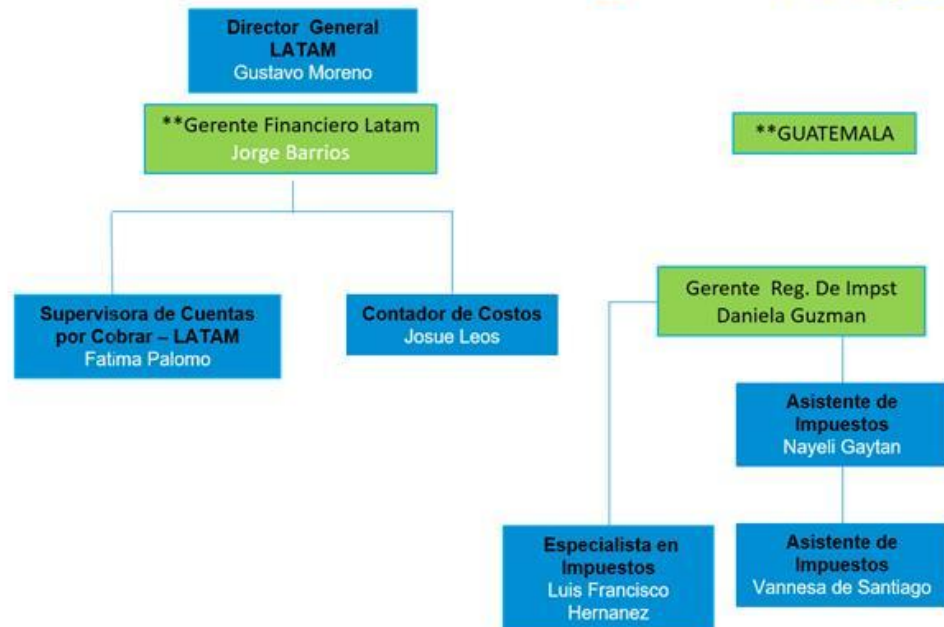


Ilustración 4 Organización México

## 1. Alcance

En la presente sección se establece la delimitación del Sistema de Gestión de Seguridad de la Información (SGSI) aplicado al área de Investigación y Desarrollo (R&D) de ProAmpac, enfocado en la protección de la información generada, procesada y almacenada durante el desarrollo de productos de empaque flexible.

El alcance del SGSI comprende las actividades relacionadas con el diseño, formulación, validación y optimización de productos, así como la generación y gestión de documentación técnica, incluyendo hojas técnicas, especificaciones de producto, estándares de empaque y TAMUs (guías visuales de calidad). Estas actividades implican el manejo de información crítica asociada a formulaciones, estructuras de materiales y parámetros de desempeño, la cual es utilizada posteriormente en los procesos de producción.

Asimismo, se incluyen dentro del alcance los procesos de pruebas y validación de materiales, soporte técnico a producción, mejora continua e innovación de productos, los cuales dependen directamente del acceso y uso adecuado de la información técnica. Se considera también la gestión de la información dentro de plataformas digitales como SharePoint, donde se almacenan bases de datos de formulaciones y documentación técnica, así como los controles de acceso, permisos y trazabilidad de modificaciones realizados por el personal autorizado.

El SGSI abarca al personal del área de R&D de la planta de San Luis Potosí, así como sus interacciones con otras áreas funcionales como producción, calidad, compras y comercial, que hacen uso de la información generada. Se incluyen los mecanismos de clasificación, almacenamiento, control documental y gestión de versiones de la información.

El sistema tiene como objetivo garantizar la confidencialidad, integridad y disponibilidad de la información, mitigando riesgos asociados a accesos no autorizados, alteraciones indebidas, pérdida de información o uso inapropiado de datos sensibles, asegurando la continuidad operativa y la protección del conocimiento técnico de la organización.



## 2. Referencias normativas

Para la implementación, mantenimiento y mejora continua del Sistema de Gestión de Seguridad de la Información de ProAmpac Planta San Luis, se consideran las siguientes normas y documentos normativos como referencia complementaria a la norma ISO/IEC 27001:2022. Estas normas proporcionan lineamientos, controles, metodologías y buenas prácticas aplicables al entorno de seguridad de la información de la organización.

1. **ISO/IEC 27000:2022 – Information Security, Cybersecurity and Privacy Protection — Information Security Management Systems — Overview and Vocabulary**  
Proporciona los conceptos fundamentales, principios y vocabulario oficial utilizados en el desarrollo e implementación del SGSI.
2. **ISO/IEC 27001:2022 – Information Security Management Systems — Requirements**  
Norma principal que establece los requisitos para establecer, implementar, mantener y mejorar continuamente un Sistema de Gestión de Seguridad de la Información.
3. **ISO/IEC 27002:2022 – Information Security Controls**  
Proporciona buenas prácticas y lineamientos para la selección, implementación y gestión de controles de seguridad de la información.
4. **ISO/IEC 27005:2022 – Information Security Risk Management**  
Define directrices para la gestión de riesgos relacionados con la seguridad de la información, incluyendo identificación, análisis, evaluación y tratamiento de riesgos.
5. **ISO/IEC 27017:2015 – Code of Practice for Information Security Controls Based on ISO/IEC 27002 for Cloud Services**  
Establece controles adicionales de seguridad para servicios en la nube, relevantes para el uso de Microsoft 365, OneDrive y SharePoint dentro de la organización.
6. **ISO/IEC 27018:2019 – Protection of Personally Identifiable Information (PII) in Public Clouds**  
Proporciona lineamientos para la protección de información personal identificable almacenada o procesada en servicios de nube pública.
7. **ISO/IEC 27701:2019 – Privacy Information Management System (PIMS)**  
Extensión de ISO/IEC 27001 e ISO/IEC 27002 orientada a la gestión de privacidad y protección de datos personales.
8. **ISO 22301:2019 – Business Continuity Management Systems — Requirements**  
Norma relacionada con la continuidad del negocio y recuperación ante desastres, aplicable a la disponibilidad de servicios críticos y respaldo de información.

9. **ISO/IEC 27035-1:2023 – Information Security Incident Management**  
Proporciona lineamientos para la gestión de incidentes de seguridad de la información, incluyendo detección, respuesta y recuperación.
10. **ISO/IEC 27004:2016 – Information Security Management — Monitoring, Measurement, Analysis and Evaluation**  
Establece directrices para medir la efectividad del SGSI mediante indicadores y métricas de desempeño.
11. **ISO/IEC 27031:2011 – Guidelines for Information and Communication Technology Readiness for Business Continuity**  
Proporciona lineamientos para garantizar la continuidad operativa de la infraestructura tecnológica y servicios críticos de TI.
12. **ISO/IEC 27033-1:2015 – Network Security**  
Define principios y lineamientos relacionados con la seguridad de redes, segmentación, firewalls y protección de comunicaciones.
13. **ISO/IEC 27040:2015 – Storage Security**  
Establece recomendaciones para la protección de sistemas de almacenamiento y respaldo de información.

### 3. Términos y Definiciones

De acuerdo con la estructura de la norma internacional ISO/IEC 27001:2022, esta sección establece el vocabulario técnico fundamental para la interpretación del Sistema de Gestión de Seguridad de la Información implementado en ProAmpac Planta San Luis.

La norma ISO/IEC 27001 no contiene definiciones propias en su cuerpo principal. En su lugar, se hace referencia normativa al documento ISO 27000:2022 "Sistemas de Gestión de Seguridad de la Información Visión General y Vocabulario", el cual contiene las 81 definiciones oficiales utilizadas en este estándar.

#### 3.1 Glosario de Términos

A continuación, se describen los términos de mayor relevancia para el alcance de este proyecto, adaptados al entorno de la organización:

| Término               | Definición (ISO/IEC 27000)                                                                                                                   | Aplicación en ProAmpac Planta SLP                                                                   |
|-----------------------|----------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------|
| Control de acceso     | Medios para asegurar que el acceso a los activos está restringido a personas autorizadas basándose en requerimientos de negocio y seguridad. | Gestión de permisos en SharePoint, acceso a la red LAN/WiFi y autenticación en cuentas.             |
| Activo de información | Conocimiento o datos que tienen valor para la organización.                                                                                  | Incluye el ERP, diseños de empaques, "know-how" técnico y configuraciones de PLCs.                  |
| Riesgo                | Efecto de la incertidumbre sobre los objetivos (Confidencialidad, Integridad y Disponibilidad).                                              | Posibilidad de pérdida de datos críticos o interrupción de la línea de producción por fallos en TI. |
| Evaluación de riesgo  | Proceso global de identificación de riesgos, análisis de riesgos y valoración de riesgos.                                                    | Análisis de amenazas sobre los servidores físicos y las estaciones de trabajo de R&D.               |
| Alta dirección        | Persona o grupo de personas que dirige y controla una organización al más alto nivel.                                                        | Gerencia de la planta responsable de asignar presupuesto para firewalls y sistemas de respaldo.     |

|                              |                                                                                                                           |                                                                                                        |
|------------------------------|---------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------|
| Confidencialidad             | Propiedad de que la información no se ponga a disposición ni se revele a individuos, entidades o procesos no autorizados. | Protección de patentes y diseños exclusivos de clientes frente a accesos externos no autorizados.      |
| Integridad                   | Propiedad de exactitud y completitud de la información y los activos.                                                     | Garantizar que las recetas de fabricación y reportes de laboratorio no sean alterados erróneamente.    |
| Disponibilidad               | Propiedad de ser accesible y utilizable a petición de una entidad autorizada cuando ésta lo requiera.                     | Asegurar que el sistema de almacenamiento compartido y el correo electrónico funcionen 24/7.           |
| Amenaza                      | Causa potencial de un incidente no deseado, que puede resultar en daño a un sistema o a la organización.                  | Riesgos de ransomware, desastres naturales o sabotaje a la infraestructura industrial (OT).            |
| Vulnerabilidad               | Debilidad de un activo o control que puede ser explotada por una o más amenazas.                                          | Falta de actualizaciones en sistemas operativos o ausencia de segmentación en la red de la planta.     |
| Incidente de seguridad       | Evento o serie de eventos inesperados que tienen una probabilidad significativa de comprometer las operaciones.           | Detección de malware en la red interna o acceso no autorizado a los servidores de datos.               |
| Parte interesada             | Persona u organización que puede afectar, verse afectada o percibirse como afectada por una decisión o actividad.         | Clientes globales, proveedores de materia prima y el personal operativo de mantenimiento.              |
| Declaración de aplicabilidad | Documento que identifica los controles necesarios y justificados para el SGSI de la organización.                         | El listado que define cuáles de los 93 controles de la norma son obligatorios para la planta San Luis. |

*Ilustración 7 Términos desarrollados*



## 4. Contexto de la organización

Especificar todos los activos de manera específica conforme a la empresa, marca, modelo, características

### 4.1 Activos internos:

1. Fórmulas para creación de productos generada en la empresa
  - Información confidencial desarrollada por el área de R&D que contiene composiciones, materiales y parámetros técnicos utilizados en la fabricación de empaques flexibles. Representa parte del know-how y ventaja competitiva de la organización.
2. Hojas técnicas de productos generada en la empresa
  - Documentación técnica interna que define especificaciones, propiedades físicas, químicas y funcionales de los productos desarrollados por ProAmpac.
3. Estándares de empaque
  - Documentos internos que establecen lineamientos de diseño, calidad y fabricación aplicables a los productos desarrollados dentro de la organización.
4. TAMUs (guías visuales)
  - Guías visuales utilizadas para validar características de calidad, impresión y apariencia del producto durante procesos de manufactura y validación.
5. Especificaciones de producto
  - Documentación técnica que define dimensiones, materiales, tolerancias y parámetros de desempeño requeridos para fabricación y validación de productos.
6. Resultados de pruebas de laboratorio
  - Información generada durante pruebas físicas, químicas y funcionales realizadas en materiales y productos desarrollados por el área de R&D.
7. Reportes de validación
  - Documentos internos que registran resultados de validaciones técnicas, pruebas piloto y liberaciones de procesos o productos.
8. Contratos con clientes
  - Documentos legales y comerciales administrados internamente que contienen acuerdos de confidencialidad, especificaciones y condiciones de servicio.
9. Propiedad intelectual (patentes)
  - Activos legales y tecnológicos que protegen desarrollos, diseños y tecnologías creadas por la organización.
10. Diseños de empaque

- Archivos digitales y documentación gráfica desarrollada por ProAmpac para clientes y proyectos internos, considerados información confidencial.
11. Documentación de procesos de manufactura
    - Procedimientos, instrucciones y parámetros operativos utilizados en producción, almacenados dentro de la red corporativa y utilizados para asegurar consistencia operativa.
  12. Instructivos de máquinas
    - Documentación técnica utilizada por operadores y personal de mantenimiento para la correcta operación y configuración de equipos industriales.
  13. Reportes de auditorías
    - Documentos generados durante auditorías internas o externas relacionados con cumplimiento, calidad y seguridad de la información.
  14. Laptops corporativas (DELL Latitude 5420, Latitude 5430 y Latitude 5450) y PC corporativa (Optiplex 7020 Micro)
    - Equipos de cómputo utilizados por personal administrativo y técnico para acceso a sistemas corporativos, almacenamiento de información y operación diaria.
  15. Documentación de políticas
    - Conjunto de políticas, lineamientos y procedimientos internos relacionados con seguridad de la información, operación y cumplimiento normativo.
  16. Sistema ERP (M3)
    - Plataforma corporativa utilizada para gestionar procesos operativos, manufactura, inventarios, finanzas y cadena de suministro de la organización.
  17. Sistema de servicio en la nube Microsoft OneDrive o Sharepoint
    - Servicios corporativos utilizados para almacenamiento, colaboración y gestión documental de información técnica y administrativa de la empresa.
  18. VPN (ZSCALER)
    - Herramienta de acceso remoto seguro utilizada para conectar usuarios autorizados a la red corporativa mediante canales cifrados y controles de autenticación.
  19. Switches (CISCO Catalyst 9200L y Fortinet FortiSwitch FS-124F-POE)
    - Equipos de red encargados de gestionar la conectividad interna, segmentación y transmisión segura del tráfico dentro de la infraestructura corporativa.
  20. Firewall (Fortinet Fortigate 30E, Fortigate 60E y Fortigate 60F)
    - Dispositivos de seguridad perimetral utilizados para controlar, monitorear y filtrar el tráfico de red, protegiendo la infraestructura contra amenazas externas.

## 4.2 Activos externos:

1. Información de clientes
  - Datos de clientes que pueden incluir especificaciones técnicas, requerimientos de productos, información de contacto y condiciones comerciales. Su manejo debe ser seguro es esencial para mantener la confianza y cumplir con acuerdos de confidencialidad.
2. Contratos con clientes
  - Documentos legales que establecen compromisos, responsabilidades y condiciones de servicio entre la organización y sus clientes. Se negocian y validan con partes fuera de la empresa.
3. Propiedad intelectual (patentes)
  - Derechos registrados ante organismos oficiales que protegen invenciones o diseños. Aunque pueden ser propiedad de la empresa, su registro y validación se realizan ante entidades externas.
4. Datos de proveedores
  - Información sobre empresas que suministran materiales, servicios o tecnología. Incluye datos de contacto, condiciones de compra y certificaciones.
5. Estándares de empaque (si son normas internacionales o de clientes)
  - Normas técnicas o regulatorias que definen requisitos de diseño, materiales y etiquetado. Son externas cuando provienen de clientes, organismos reguladores o estándares internacionales.
6. Plataforma SAP
  - que gestiona la cadena de suministro y finanzas desde servidores remotos.
7. Microsoft 365
  - Donde se almacena y comparte propiedad intelectual y diseños de empaques.
8. Copias de seguridad externas
  - Para garantizar la recuperación ante desastres. Garantiza la seguridad de la empresa y la protección de datos en situaciones de desastre
9. Software de terceros
  - Para el seguimiento de camiones y contenedores que transportan el producto terminado a los clientes.
10. Sistemas del SAT
  - Herramientas para la emisión de facturación electrónica (CFDI), presentación de declaraciones, cumplimiento de obligaciones fiscales y gestión del Buzón Tributario para notificaciones oficiales.
11. Portales de ventanilla única para el comercio exterior.
  - Plataforma digital que permite agilizar los trámites de importación y exportación, centralizando los requisitos de diversas dependencias gubernamentales para el despacho de mercancías.

12. Diseños proporcionados por clientes:
  - Planos, artes gráficas o modelos de empaque que el cliente entrega para su producción. Al ser propiedad del cliente, requieren un manejo estricto bajo acuerdos de propiedad industrial y confidencialidad.
13. Fórmulas y licencias externas
  - Recetas químicas, composiciones de materiales o derechos de uso de software especializado que no pertenecen a la empresa, pero que son necesarios para la fabricación del producto final.
14. Sistemas del IMSS
  - Plataformas para el registro de altas, bajas y modificaciones salariales de los empleados. Es un punto crítico de intercambio de datos personales y financieros con el organismo de seguridad social.
15. Portales de ISO donde se suben evidencias de auditorías, controles de calidad y seguridad alimentaria.
  - Repositorios externos donde se cargan resultados de auditorías, manuales de calidad y controles de inocuidad alimentaria para obtener o mantener certificaciones internacionales de estandarización.
16. Plataformas externas para la dispersión de pagos
  - Sistemas financieros de terceros utilizados para el pago de nómina, liquidación a proveedores y transferencias electrónicas, los cuales cuentan con protocolos de seguridad bancaria externos.
17. Plataforma externa para gestión de seguros de gastos médicos
  - Portales de aseguradoras donde se gestionan las pólizas de los empleados, siniestros y coberturas, manejando información sensible sobre la salud del personal.
18. Servicio de correo electrónico externo de clientes / proveedores
  - Servidores y dominios ajenos a la organización a través de los cuales fluye información operativa, logística y comercial, representando un punto de contacto constante con el exterior.
19. Servicios de consultoría externa (auditores, ingenieros, IT)
  - Acceso otorgado a auditores, ingenieros o personal de IT externo para revisar procesos, infraestructuras o estados financieros, lo que implica un intercambio controlado de datos internos.
20. Licencias de software de terceros (no administradas localmente)
  - Aplicaciones en la nube cuyos servidores, actualizaciones y seguridad dependen totalmente del proveedor del software, limitando el control directo de la empresa sobre la infraestructura.

## 5. Liderazgo

### 5.1 Política General de Seguridad ProAmpac

#### 5.1.1 Objetivo:

Establecer los lineamientos para proteger la confidencialidad, integridad y disponibilidad de la información crítica generada y gestionada en el área de Investigación y Desarrollo (R&D) de ProAmpac Planta San Luis, asegurando su uso adecuado y la mitigación de riesgos asociados a accesos no autorizados, pérdida de información, alteraciones indebidas o uso inapropiado.

Asimismo, esta política busca:

- Proteger el know-how técnico, formulaciones y diseños de empaque desarrollados por la organización.
- Garantizar la seguridad de la información compartida con clientes y proveedores.
- Asegurar la continuidad operativa de los procesos de desarrollo, validación y soporte técnico.
- Cumplir con los requisitos legales, regulatorios y contractuales aplicables en materia de seguridad de la información.
- Fortalecer una cultura organizacional orientada a la seguridad de la información y gestión de riesgos.

#### 5.1.2 Alcance:

Esta política aplica a:

- Todo el personal del área de Investigación y Desarrollo (R&D) de ProAmpac Planta San Luis.
- Empleados, contratistas, proveedores y terceros que tengan acceso a información o sistemas de la organización.
- Todos los activos de información dentro del alcance del SGSI, incluyendo:

Información

- Formulaciones de productos
- Hojas técnicas
- Especificaciones y diseños de empaque
- Resultados de laboratorio y reportes de validación
- Información de clientes y proveedores



### Sistemas y plataformas

- ERP (M3)
- Microsoft 365 (incluyendo SharePoint y OneDrive)
- Sistemas de control documental
- VPN (Zscaler)

### Infraestructura tecnológica

- Servidores físicos y virtuales
- Equipos de usuario (laptops, PCs)
- Redes LAN/WiFi
- Firewalls y switches

### Entornos de operación

- Red corporativa
- Plataformas en la nube
- Interfaces con sistemas externos (clientes, SAT, proveedores)

## 5.1.3 Compromiso de la Dirección:

La alta dirección de ProAmpac Planta San Luis se compromete a:

- Proveer los recursos humanos, tecnológicos y financieros necesarios para la implementación, mantenimiento y mejora continua del SGSI.
- Asegurar que la seguridad de la información esté alineada con los objetivos estratégicos del negocio.
- Establecer y comunicar esta política a todos los niveles de la organización y partes interesadas relevantes.
- Promover una cultura organizacional de seguridad, mediante programas de concientización y capacitación continua.
- Garantizar la gestión de riesgos de seguridad de la información, identificando amenazas y vulnerabilidades asociadas a los activos críticos.
- Supervisar el cumplimiento de esta política mediante auditorías internas, revisiones periódicas y métricas de desempeño.
- Asegurar el cumplimiento de requisitos legales, regulatorios, contractuales y normativos (incluyendo ISO 27001).
- Fomentar la mejora continua del SGSI mediante la implementación de acciones correctivas y preventivas.

## 5.2 Políticas Funcionales

### 5.2.1 Gestión de acceso

**Estándar:** Definir y gestionar los accesos de todos los usuarios autorizados.

**Directriz:** Realizar auditorías periódicas de los permisos de acceso.

**Procedimiento:** Establecer un proceso para solicitar y aprobar nuevos accesos.

**Línea base:** Todos los usuarios deben cambiar sus contraseñas cada 90 días.

### 5.2.2 Implementación de actualizaciones

**Estándar:** Gestionar e implementar actualizaciones oficiales periódicamente para todos los usuarios.

**Directriz:** Realizar actualizaciones periódicas de los servicios de Microsoft 365.

**Procedimiento:** Establecer un proceso para solicitar y aprobar nuevas actualizaciones en los servicios necesarios.

**Línea base:** Realizar el proceso de actualización cada cierto periodo fijo previamente establecido.

### 5.2.3 Recuperación ante desastres

**Estándar:** Garantizar la disponibilidad y recuperación de la información crítica y servicios tecnológicos ante incidentes, fallos o desastres.

**Directriz:** Realizar respaldos automáticos periódicos y pruebas de restauración de la información crítica.

**Procedimiento:** Establecer un plan formal de recuperación ante desastres que contemple responsables, tiempos de recuperación y validación de respaldos.

**Línea base:** Todos los respaldos criterios deberán realizarse diariamente y almacenarse cifrados en una ubicación externa segura.

### 5.2.4 Gestión de respaldos de información

**Estándar:** Proteger la información corporativa mediante mecanismos seguros de respaldo y recuperación.

**Directriz:** Verificar periódicamente la integridad y disponibilidad de las copias de seguridad.

**Procedimiento:** Ejecutar respaldos automáticos de servidores, SharePoint y documentación crítica siguiendo calendarios establecidos.

**Línea base:** Los respaldos deberán conservarse mínimo 90 días y contar con cifrado AES-256.

### 5.2.5 Gestión de incidentes de seguridad

**Estándar:** Detectar, registrar y responder oportunamente a incidentes de seguridad de la información.

**Directriz:** Mantener canales de reporte accesibles para todos los usuarios y áreas

involucradas.

**Procedimiento:** Establecer un flujo de identificación, clasificación, escalamiento y cierre de incidentes de seguridad.

**Línea base:** Todo incidente deberá registrarse y atenderse en un periodo máximo de 24 horas desde su detección.

### 5.2.6 Seguridad del correo electrónico corporativo

**Estándar:** Proteger el servicio de correo electrónico contra accesos no autorizados, phishing y malware.

**Directriz:** Capacitar periódicamente al personal sobre amenazas de ingeniería social y correos fraudulentos.

**Procedimiento:** Implementar filtros antispam, análisis antivirus y monitoreo de actividad sospechosa en cuentas corporativas.

**Línea base:** Todas las cuentas deberán utilizar MFA y bloqueo automático tras múltiples intentos fallidos de acceso.

### 5.2.7 Gestión de dispositivos móviles y remotos

**Estándar:** Garantizar la seguridad de los dispositivos móviles y equipos utilizados fuera de la red corporativa.

**Directriz:** Restringir el acceso remoto únicamente a dispositivos autorizados y administrados por la organización.

**Procedimiento:** Registrar y validar todos los dispositivos móviles con acceso a información corporativa antes de su autorización.

**Línea base:** Todo dispositivo remoto deberá contar con antivirus activo, cifrado de disco y conexión mediante VPN corporativa.

### 5.2.8 Clasificación y manejo de la información

**Estándar:** Clasificar la información de acuerdo con su nivel de sensibilidad y criticidad para la organización.

**Directriz:** Etiquetar la información confidencial y limitar su acceso únicamente a personal autorizado.

**Procedimiento:** Definir categorías de clasificación y procedimientos para almacenamiento, transmisión y eliminación segura de información.

**Línea base:** Toda información técnica de R&D deberá clasificarse como “Confidencial”.

### 5.2.9 Seguridad física y ambiental

**Estándar:** Proteger las instalaciones, equipos y activos críticos contra accesos físicos no autorizados y daños ambientales.

**Directriz:** Restringir el acceso a áreas críticas mediante controles físicos y monitoreo continuo.

**Procedimiento:** Implementar registros de visitantes, controles de acceso físico y monitoreo mediante CCTV.

**Línea base:** Las áreas de servidores y telecomunicaciones deberán permanecer cerradas y con acceso únicamente a personal autorizado.

### 5.2.10 Capacitación y concientización en seguridad

**Estándar:** Fortalecer la cultura organizacional de seguridad de la información mediante capacitación continua.

**Directriz:** Realizar campañas periódicas sobre buenas prácticas de seguridad y prevención de riesgos cibernéticos.

**Procedimiento:** Programar capacitaciones obligatorias y evaluaciones de conocimiento para empleados y terceros.

**Línea base:** Todo colaborador deberá completar al menos una capacitación de seguridad de la información cada 12 meses.

### 5.2.11 Gestión y Custodia de Contratos con Clientes

**Estándar:** Garantizar la confidencialidad, integridad y disponibilidad de todos los documentos contractuales.

**Directriz:** Realizar revisiones semestrales de los niveles de acceso y del estado físico/digital de los contratos.

**Procedimiento:** Establecer un proceso de solicitud formal ante el área legal para la consulta o préstamo de expedientes.

**Línea base:** Todos los contratos digitales deben estar cifrados y los físicos bajo llave con acceso restringido.

### 5.2.12 Seguridad y Control de Dispositivos de Cómputo

**Estándar:** Asegurar que las Laptops (Dell Latitude) y PC (Optiplex) cuenten con las configuraciones de seguridad de fábrica y corporativas.

**Directriz:** Realizar mantenimientos preventivos y actualizaciones de BIOS/Firmware de forma trimestral.

**Procedimiento:** Establecer un registro de asignación de activos donde se firme la responsabilidad del resguardo del equipo.

**Línea base:** Todos los equipos deben tener activo el cifrado de disco BitLocker y el bloqueo de pantalla a los 5 minutos.

### 5.2.13 Almacenamiento Seguro en OneDrive y SharePoint

**Estándar:** Controlar el flujo de información y la colaboración en servicios de nube corporativos.

**Directriz:** Monitorear y auditar los enlaces compartidos con usuarios externos a la organización periódicamente.

**Procedimiento:** Establecer un proceso para la creación de carpetas compartidas que requiere la clasificación previa de la información.

**Línea base:** Es obligatorio el uso de Autenticación de Múltiple Factor (MFA) para acceder a cualquier servicio de Microsoft 365.

#### 5.2.14 Fórmulas para creación de productos

**Estándar:** Toda fórmula de producto debe clasificarse como información confidencial y mantenerse protegida contra acceso no autorizado.

**Directriz:** Se recomienda aplicar cifrado de extremo a extremo y controles de acceso basados en roles para los archivos que contengan fórmulas.

**Procedimiento:** Registrar cada acceso o modificación mediante bitácoras automáticas y validar la identidad del usuario antes de permitir cambios.

**Línea base:** Las fórmulas se almacenan en servidores internos seguros con copias de respaldo cifradas y verificación semanal de integridad.

#### 5.2.15 Documentación de procesos de manufactura

**Estándar:** Toda documentación relacionada con procesos de manufactura debe mantenerse protegida contra modificaciones no autorizadas, pérdida de información o divulgación indebida.

**Directriz:** Se recomienda implementar controles de versionado, permisos de edición restringidos y almacenamiento centralizado dentro de plataformas corporativas seguras.

**Procedimiento:** Registrar y aprobar formalmente cualquier modificación a procedimientos, instructivos o parámetros operativos antes de su liberación a producción.

**Línea base:** Toda documentación deberá almacenarse en servidores corporativos o SharePoint con respaldo automático diario y control de acceso basado en roles.

#### 5.2.16 Reportes de auditorías

**Estándar:** Todos los reportes de auditoría interna o externa deben clasificarse como información confidencial y mantenerse disponibles únicamente para personal autorizado.

**Directriz:** Se recomienda aplicar mecanismos de cifrado y trazabilidad documental para asegurar la integridad y autenticidad de los reportes.

**Procedimiento:** Establecer un flujo formal para la generación, revisión, aprobación, almacenamiento y eliminación controlada de reportes de auditoría.

**Línea base:** Los reportes deberán conservarse por un periodo mínimo de 5 años en repositorios seguros con respaldo automático y registro de accesos habilitado.

#### 5.2.17 Seguridad y Control de Acceso del Sistema ERP (M3)

**Estándar:** Garantizar la disponibilidad, integridad y confidencialidad de la información financiera, de manufactura y operativa gestionada en el ERP.

**Directriz:** Implementar controles de acceso basados en roles (RBAC) y principio de mínimo privilegio para prevenir alteraciones no autorizadas o fraudes internos.

**Procedimiento:** Establecer un proceso formal de tickets para la solicitud, aprobación y revocación de accesos, realizando auditorías trimestrales de las cuentas activas y sus permisos.

**Línea base:** Requerir autenticación de múltiple factor (MFA) para todo inicio de sesión y asegurar el cifrado de datos tanto en tránsito como en reposo.

#### 5.2.18 Acceso remoto seguro mediante VPN Zscaler

**Estándar:** Proveer un canal de acceso remoto seguro a los activos y red corporativa de ProAmpac exclusivamente para personal y dispositivos autorizados.

**Directriz:** Aplicar principios de Zero Trust (confianza cero), verificando continuamente la identidad del usuario y el estado de seguridad del dispositivo antes de conceder el acceso.

**Procedimiento:** Monitorear y auditar los registros de conexión VPN mensualmente para identificar patrones anómalos o intentos de acceso desde ubicaciones geográficas no esperadas.

**Línea base:** Uso obligatorio de cifrado robusto (ej. AES-256) para el túnel VPN, MFA activo para todos los usuarios y bloqueo automático de la cuenta tras 5 intentos fallidos.

#### 5.2.19 Gestión Segura de Switches de Red Corporativa

**Estándar:** Asegurar la disponibilidad de la red interna (LAN) y mantener una estricta segmentación del tráfico para proteger los flujos de información y evitar movimientos laterales en caso de intrusión.

**Directriz:** Mantener el firmware actualizado e implementar configuraciones de endurecimiento (hardening) siguiendo las mejores prácticas de seguridad de Cisco y Fortinet.

**Procedimiento:** Realizar respaldos automáticos de las configuraciones de red de manera semanal y documentar formalmente cualquier cambio topológico o de reglas de enrutamiento.

**Línea base:** Deshabilitar administrativamente todos los puertos físicos inactivos, implementar seguridad a nivel de puerto (802.1X / Port Security) y aislar el tráfico mediante VLANs (separando R&D, OT/Planta y Corporativo).

#### 5.2.20 Seguridad Perimetral mediante Firewalls Corporativos

**Estándar:** Proteger el perímetro de la red corporativa contra amenazas externas, intrusiones y filtración de datos, controlando el tráfico entrante y saliente.

**Directriz:** Aplicar la política de "denegación por defecto" (default deny), permitiendo únicamente el tráfico estrictamente necesario para las operaciones del negocio.

**Procedimiento:** Revisar, justificar y depurar el conjunto de reglas del firewall de forma semestral, eliminando accesos obsoletos o excesivamente permisivos.

**Línea base:** Mantener activos los módulos de Prevención de Intrusiones (IPS), filtrado web y antivirus perimetral, con actualización automática de firmas de amenazas.



### 5.3 Matriz RACI

#### Roles

| Sigla | Rol / Área                                |
|-------|-------------------------------------------|
| AD    | Alta Dirección / Gerencia de Operaciones  |
| SGSI  | Responsable SGSI                          |
| TI    | Área de Infraestructura TI                |
| M365  | Administrador Microsoft 365               |
| R&D   | Responsable de Investigación y Desarrollo |
| RH    | Recursos Humanos                          |
| LEG   | Área Legal                                |
| CAL   | Área de Calidad                           |
| USERS | Usuarios / Colaboradores                  |

Ilustración 8 Roles/Áreas de la empresa

#### Leyenda

|   |             |
|---|-------------|
| R | Responsable |
| A | Aprobador   |
| C | Consultado  |
| I | Informado   |

| Política / Control                           | AD | SGSI | TI  | M365 | R&D | RH | LEG | CAL | USERS |
|----------------------------------------------|----|------|-----|------|-----|----|-----|-----|-------|
| Gestión de acceso                            | I  | A    | R   | C    | C   | I  |     |     | I     |
| Implementación de actualizaciones            | I  | C    | A R | R    | I   |    |     |     | I     |
| Recuperación ante desastres                  | A  | R    | R   | C    | I   |    |     |     | I     |
| Gestión de respaldos de información          | I  | A    | R   | R    | C   |    |     |     | I     |
| Gestión de incidentes de seguridad           | I  | A R  | R   | C    | C   | I  |     |     | I     |
| Seguridad del correo electrónico corporativo | I  | C    | R   | A R  | I   | C  |     |     | I     |
| Gestión de dispositivos móviles y remotos    | I  | C    | A R | C    | I   |    |     |     | I     |
| Clasificación y manejo de la información     | I  | A    | C   | C    | R   | I  | C   | C   | I     |

|                                                      |   |   |   |   |   |   |   |   |   |
|------------------------------------------------------|---|---|---|---|---|---|---|---|---|
| Seguridad física y ambiental                         | A | C | R |   | I | I |   |   | I |
| Capacitación y concientización en seguridad          | I | C | C |   | I | A | R |   | R |
| Gestión y Custodia de Contratos con Clientes         | I | C | C |   | I |   | A | R | I |
| Seguridad y Control de Dispositivos de Cómputo       | I | C | A | R | I |   |   |   | R |
| Almacenamiento Seguro en OneDrive y SharePoint       | I | C | C | A | R | R |   |   | I |
| Fórmulas para creación de productos                  | I | C | C | C | A | R |   | C | I |
| Documentación de procesos de manufactura             | I | C | C |   | A | R |   | C | I |
| Reportes de auditorías                               | I | A | R | C | C | I | C | C | I |
| Seguridad y Control de Acceso del Sistema ERP (M3)   | I | C | A | R | C | C | I |   | I |
| Acceso remoto seguro mediante VPN Zscaler            | I | C | A | R |   | I |   |   | I |
| Gestión Segura de Switches de Red Corporativa        | I | C | A | R |   |   |   |   | I |
| Seguridad Perimetral mediante Firewalls Corporativos | I | C | A | R |   |   |   |   | I |

Ilustración 9 Matriz RACI en ProAmpac

## 6. Planificación

En esta sección se identifican y evalúan los riesgos relacionados con la seguridad de la información dentro del SGSI de ProAmpac Planta San Luis. Cada riesgo está asociado a las políticas funcionales definidas en la Sección 5.2, con el objetivo de establecer acciones y controles que ayuden a reducir impactos, prevenir incidentes y proteger la confidencialidad, integridad y disponibilidad de la información crítica de la organización.

### 6.1 Clasificación de riesgos

#### 6.1.1 Accesos no autorizados a sistemas críticos

**Probabilidad:** Media

**Impacto:** Crítico (Exposición de información confidencial, alteración de datos y afectación operativa).

**Riesgo:** Alto

**Administración del riesgo:** Mitigar

**Acción:** Implementar controles RBAC, autenticación multifactorial, auditorías periódicas de privilegios y revocación inmediata de accesos no autorizados.

#### 6.1.2 Vulnerabilidades por falta de actualizaciones

**Probabilidad:** Alta

**Impacto:** Alto (Explotación de vulnerabilidades y compromiso de infraestructura crítica).

**Riesgo:** Alto

**Administración del riesgo:** Mitigar

**Acción:** Establecer calendario obligatorio de actualización, monitoreo automatizado y validación de parches en servicios Microsoft 365 y sistemas internos.

#### 6.1.3 Pérdida de información por desastres o fallos críticos

**Probabilidad:** Media

**Impacto:** Crítico (Interrupción operativa total y pérdida irreversible de activos de información).

**Riesgo:** Extremo

**Administración del riesgo:** Mitigar

**Acción:** Implementar respaldos externos automáticos, pruebas periódicas de restauración y planes documentados de continuidad operativa.

#### 6.1.4 Corrupción o pérdida de respaldos

**Probabilidad:** Media

**Impacto:** Alto (Imposibilidad de recuperación ante incidentes).

**Riesgo:** Alto

**Administración del riesgo:** Mitigar

**Acción:** Validar integridad semanal de respaldos, cifrado obligatorio y redundancia geográfica de almacenamiento.

#### 6.1.5 Respuesta tardía ante incidentes de seguridad

**Probabilidad:** Media

**Impacto:** Alto (Escalamiento de incidentes y mayores daños operativos).

**Riesgo:** Alto

**Administración del riesgo:** Mitigar

**Acción:** Implementar protocolos de respuesta inmediata, registro obligatorio y escalamiento automatizado de incidentes críticos.

#### 6.1.6 Ataques de phishing o malware vía correo electrónico

**Probabilidad:** Alta

**Impacto:** Alto (Robo de credenciales, ransomware o fuga de información).

**Riesgo:** Extremo

**Administración del riesgo:** Mitigar

**Acción:** Aplicar filtros avanzados antiphishing, MFA obligatorio, capacitación continua y monitoreo de actividad sospechosa.

#### 6.1.7 Compromiso de dispositivos remotos o móviles

**Probabilidad:** Media

**Impacto:** Alto (Acceso indebido a información corporativa desde dispositivos vulnerables).

**Riesgo:** Alto

**Administración del riesgo:** Mitigar

**Acción:** Restringir acceso a dispositivos administrados, cifrado obligatorio y monitoreo remoto de cumplimiento.

#### 6.1.8 Divulgación indebida de información confidencial

**Probabilidad:** Media

**Impacto:** Crítico (Pérdida de propiedad intelectual y afectación contractual con clientes).

**Riesgo:** Extremo

**Administración del riesgo:** Mitigar

**Acción:** Etiquetado obligatorio de información, controles de acceso por clasificación y monitoreo de transferencia de archivos.

#### 6.1.9 Intrusión física o daño ambiental a infraestructura

**Probabilidad:** Baja-Media

**Impacto:** Alto (Interrupción de servicios tecnológicos y daño de activos críticos).

**Riesgo:** Alto

**Administración del riesgo:** Mitigar

**Acción:** Controles biométricos, CCTV, alarmas ambientales y monitoreo continuo de áreas restringidas.

#### 6.1.10 Falta de cultura organizacional en seguridad

**Probabilidad:** Alta

**Impacto:** Medio-Alto (Errores humanos, exposición accidental de información y malas prácticas).

**Riesgo:** Alto

**Administración del riesgo:** Mitigar

**Acción:** Programas obligatorios de capacitación anual, simulaciones de phishing y evaluaciones periódicas de concientización.

#### 6.1.11 Fuga o acceso no autorizado a información contractual de clientes

**Probabilidad:** Media

**Impacto:** Crítico (Pérdida de confianza comercial, demandas legales por incumplimiento de confidencialidad y exposición de términos financieros)

**Riesgo:** Extremo

**Administración del riesgo:** Mitigar

**Acción:** Digitalizar contratos con cifrado AES-256, restringir el acceso físico mediante control de llaves y aplicar un sistema de solicitudes formales con registro de auditoría (logs) para cada consulta.

#### 6.1.12 Exposición de datos por robo o pérdida de equipos Dell Latitude / Optiplex

**Probabilidad:** Alta

**Impacto:** Alto (Compromiso de credenciales guardadas, acceso a archivos locales y posible intrusión a la red corporativa).

**Riesgo:** Extremo

**Administración del riesgo:** Mitigar

**Acción:** Forzar el cifrado de disco completo (BitLocker), establecer contraseñas de BIOS, implementar protocolos de borrado remoto y capacitar al personal en el reporte inmediato de incidentes (máximo 2 horas).

#### 6.1.13 Exfiltración de datos mediante enlaces de compartición pública en OneDrive/SharePoint

**Probabilidad:** Media

**Impacto:** Crítico (Acceso indexable desde internet a propiedad intelectual, diseños de empaque o reportes de laboratorio).

**Riesgo:** Extremo

**Administración del riesgo:** Mitigar

**Acción:** Configurar políticas de Prevención de Pérdida de Datos (DLP) para bloquear archivos sensibles, obligar el uso de contraseñas y fechas de expiración en enlaces externos y deshabilitar la opción de "Cualquier persona con el vínculo" de forma global.

#### 6.1.14 Exposición o robo de fórmulas de productos confidenciales

**Probabilidad:** Media-Alta

**Impacto:** Crítico (Pérdida de propiedad intelectual, ventaja competitiva y posibles incumplimientos contractuales con clientes).

**Riesgo:** Extremo

**Administración del riesgo:** Mitigar

**Acción:** Implementar cifrado de archivos, autenticación multifactor (MFA), control de acceso basado en roles (RBAC) y monitoreo continuo de accesos y modificaciones sobre repositorios de formulaciones.

#### 6.1.15 Alteración no autorizada de documentación de procesos de manufactura

**Probabilidad:** Media

**Impacto:** Alto (Errores operativos, desviaciones de producción, afectación a calidad y posibles paros de línea).

**Riesgo:** Alto

**Administración del riesgo:** Mitigar

**Acción:** Aplicar control documental con versionado, aprobación formal de cambios, respaldos automáticos y restricciones de edición únicamente a personal autorizado.



### 6.1.16 Divulgación o manipulación indebida de reportes de auditoría

**Probabilidad:** Media

**Impacto:** Alto (Incumplimientos normativos, exposición de hallazgos críticos y afectación reputacional ante clientes o certificadoras).

**Riesgo:** Alto

**Administración del riesgo:** Mitigar

**Acción:** Restringir el acceso mediante controles RBAC, cifrar los repositorios documentales y habilitar bitácoras de auditoría para rastrear consultas, descargas y modificaciones de reportes.

### 6.1.17 Alteración o robo de datos en el Sistema ERP (M3)

**Probabilidad:** Media

**Impacto:** Alto (Pérdida financiera, interrupción en la cadena de suministro o fuga de datos de clientes).

**Riesgo:** Alto

**Administración del riesgo:** Mitigar

**Acción:** Implementar estrictos controles de acceso basados en roles (RBAC), forzar el uso de MFA y habilitar el monitoreo de logs para transacciones críticas.

### 6.1.18 Acceso remoto no autorizado a través de la VPN (ZSCALER)

**Probabilidad:** Alta (Debido a la frecuencia de ataques de phishing o robo de credenciales).

**Impacto:** Alto (Posibilidad de despliegue de ransomware o acceso total a la intranet).

**Riesgo:** Extremo / Alto

**Administración del riesgo:** Mitigar

**Acción:** Limitar el acceso VPN únicamente a equipos corporativos administrados, forzar MFA y establecer alertas automatizadas para inicios de sesión sospechosos.

### 6.1.19 Interrupción o compromiso de red interna vía Switches (CISCO / Fortinet)

**Probabilidad:** Media

**Impacto:** Alto (Paro de líneas de producción, pérdida de comunicación entre áreas operativas).

**Riesgo:** Alto

**Administración del riesgo:** Mitigar

**Acción:** Configurar seguridad de puertos (bloqueo por MAC address no reconocida), segmentar la red R&D de la red de invitados/planta mediante VLANs y bloquear puertos físicos sin uso.

### 6.1.20 Intrusión perimetral por brechas en el Firewall (Fortigate)

**Probabilidad:** Media

**Impacto:** Crítico (Compromiso total de la infraestructura, exfiltración de propiedad intelectual y fórmulas).

**Riesgo:** Extremo

**Administración del riesgo:** Mitigar

**Acción:** Auditoría periódica de las reglas de filtrado, activación de sistemas IPS/IDS en modo bloqueo y aplicación inmediata de parches de seguridad liberados por el fabricante.

### 6.2 Matriz de Riesgo

| Probabilidad \ Impacto | 01 - Insignificante | 02 - Menor    | 03 - Significativo     | 04 - Mayor                                    | 05 - Severo                                  |
|------------------------|---------------------|---------------|------------------------|-----------------------------------------------|----------------------------------------------|
| 05 - Casi Seguro       | 05 (Medio)          | 10 (Alto)     | 15 (Muy Alto)<br>(R10) | 20 (Extremo)<br>(R2, R6, R12, R18)            | 25 (Extremo)                                 |
| 04 - Probable          | 04 (Medio)          | 08 (Medio)    | 12 (Alto)              | 16 (Muy Alto)                                 | 20 (Extremo)<br>(R14)                        |
| 03 - Moderado          | 03 (Bajo)           | 06 (Medio)    | 09 (Medio)             | 12 (Alto)<br>(R4, R5, R7, R15, R16, R17, R19) | 15 (Muy Alto)<br>(R1, R3, R8, R11, R13, R20) |
| 02 - Poco Probable     | 02 (Muy Bajo)       | 04 (Bajo)     | 06 (Medio)             | 08 (Medio)<br>(R9)                            | 10 (Alto)                                    |
| 01 - Raro              | 01 (Muy Bajo)       | 02 (Muy Bajo) | 03 (Bajo)              | 04 (Medio)                                    | 05 (Medio)                                   |

Ilustración 10 Matriz de Riesgo en ProAmpac

**Leyenda de Riesgos (Mapeo)**

- R1 (6.1.1): Accesos no autorizados a sistemas críticos. [Prob: 3, Imp: 5]
- R2 (6.1.2): Vulnerabilidades por falta de actualizaciones. [Prob: 5, Imp: 4]
- R3 (6.1.3): Pérdida de información por desastres o fallos críticos. [Prob: 3, Imp: 5]
- R4 (6.1.4): Corrupción o pérdida de respaldos. [Prob: 3, Imp: 4]
- R5 (6.1.5): Respuesta tardía ante incidentes de seguridad. [Prob: 3, Imp: 4]
- R6 (6.1.6): Ataques de phishing o malware vía correo electrónico. [Prob: 5, Imp: 4]
- R7 (6.1.7): Compromiso de dispositivos remotos o móviles. [Prob: 3, Imp: 4]
- R8 (6.1.8): Divulgación indebida de información confidencial. [Prob: 3, Imp: 5]
- R9 (6.1.9): Intrusión física o daño ambiental a infraestructura. [Prob: 2, Imp: 4]
- R10 (6.1.10): Falta de cultura organizacional en seguridad. [Prob: 5, Imp: 3]
- R11 (6.1.11): Fuga o acceso no autorizado a información contractual de clientes. [Prob: 3, Imp: 5]
- R12 (6.1.12): Exposición de datos por robo o pérdida de equipos Dell Latitude / Optiplex. [Prob: 5, Imp: 4]
- R13 (6.1.13): Exfiltración de datos mediante enlaces de compartición pública en OneDrive/SharePoint. [Prob: 3, Imp: 5]
- R14 (6.1.14): Exposición o robo de fórmulas de productos confidenciales. [Prob: 4, Imp: 5]
- R15 (6.1.15): Alteración no autorizada de documentación de procesos de manufactura. [Prob: 3, Imp: 4]
- R16 (6.1.16): Divulgación o manipulación indebida de reportes de auditoría. [Prob: 3, Imp: 4]
- R17 (6.1.17): Alteración o robo de datos en el Sistema ERP (M3). [Prob: 3, Imp: 4]
- R18 (6.1.18): Acceso remoto no autorizado a través de la VPN (ZSCALER). [Prob: 5, Imp: 4]
- R19 (6.1.19): Interrupción o compromiso de red interna vía Switches. [Prob: 3, Imp: 4]
- R20 (6.1.20): Intrusión perimetral por brechas en el Firewall (Fortigate). [Prob: 3, Imp: 5]

## 7. Soporte

### MINUTA DE REUNIÓN



|                                                                                                                                   |                    |             |            |
|-----------------------------------------------------------------------------------------------------------------------------------|--------------------|-------------|------------|
| COMITÉ: Comité de Seguridad de la Información                                                                                     |                    |             |            |
| Tema Convocatoria: Revisión y Seguimiento del Sistema de Gestión de Seguridad de la Información (SGSI) – Proampac Planta San Luis |                    |             |            |
| Fecha                                                                                                                             | 13 de mayo de 2026 | Hora Inicio | 10:00 a.m. |
| Modalidad                                                                                                                         | Presencial         | Hora Fin    | 10:45 a.m. |

### ASISTENCIA

| Área                                  | Nombre               |
|---------------------------------------|----------------------|
| Gerente de Operaciones                | Mario Paz            |
| Responsable SGSI                      | Vicente Rodríguez    |
| Área de Infraestructura TI            | Alberto García       |
| Administrador Microsoft 365           | Luis Martínez        |
| Responsable de R&D                    | Gabriel Cisneros     |
| Recursos Humanos                      | Edith Escalante      |
| Área de Calidad                       | Georgina Torres      |
| Comité de Seguridad de la Información | Equipo SGSI ProAmpac |

## TEMAS TRATADOS

### 1. Revisión del estado actual del SGSI

Tema revisado:

- Avance del SGSI en el área de R&D.
- Revisión de activos críticos:
  - ERP M3
  - SharePoint
  - OneDrive
  - VPN Zscaler
  - Equipos corporativos
- Validación de alineación con ISO/IEC 27001:2022.

Hallazgos:

- Inconsistencia en clasificación documental.
- Permisos compartidos sin segmentación adecuada.

Solución propuesta:

- Implementar controles RBAC.
- Clasificar información crítica bajo niveles de confidencialidad.
- Revisar permisos en repositorios compartidos.

Responsable principal:

- Área de TI

Área de apoyo:

- Responsable SGSI

Fecha compromiso:

- Junio 2026

Comentarios:

- Se priorizarán activos relacionados con propiedad intelectual y documentación técnica de R&D.

### 2. Evaluación de riesgos de seguridad de la información

Tema revisado:

- Revisión de riesgos asociados a accesos remotos y conexiones externas.

- Análisis de amenazas relacionadas con ransomware, phishing y fuga de información.
- Evaluación de controles implementados sobre:
  - VPN Zscaler
  - Firewall Fortigate
  - Microsoft 365
  - SharePoint y OneDrive
- Verificación de mecanismos de autenticación y protección de información sensible.

#### Hallazgos:

- Existencia de enlaces compartidos públicamente en plataformas colaborativas.
- Riesgo de exposición de información confidencial mediante configuraciones inadecuadas de compartición.
- Dependencia elevada de accesos remotos para personal administrativo y técnico.

#### Solución propuesta:

- Implementar políticas DLP (Data Loss Prevention) en Microsoft 365.
- Restringir enlaces públicos y habilitar fechas de expiración para compartición externa.
- Establecer MFA obligatorio para todos los usuarios corporativos.
- Incrementar monitoreo sobre accesos remotos y actividad sospechosa.

#### Responsable principal:

- Área de Infraestructura TI

#### Área de apoyo:

- Administrador Microsoft 365
- Responsable SGSI

#### Fecha compromiso:

- Junio 2026

#### Comentarios:

- Se recomendó reforzar campañas internas de concientización sobre phishing e ingeniería social.

### 3. Revisión de políticas funcionales del SGSI

Tema revisado:

- Validación de las políticas funcionales desarrolladas para el SGSI de ProAmpac Planta San Luis.
- Revisión de políticas relacionadas con:
  - Gestión de acceso
  - Recuperación ante desastres
  - Gestión de respaldos
  - Seguridad perimetral
  - Gestión de incidentes
  - Seguridad de dispositivos corporativos
  - Protección de información confidencial
- Verificación de alineación entre políticas, activos críticos y riesgos identificados.

Hallazgos:

- Algunas políticas no contaban inicialmente con responsables claramente definidos.
- Se detectó falta de periodicidad documentada para revisiones y actualizaciones de políticas.
- Existían diferencias en el nivel de detalle entre políticas funcionales.

Solución propuesta:

- Homologar la estructura de todas las políticas funcionales utilizando:
  - Estándar
  - Directriz
  - Procedimiento
  - Línea base
- Asignar responsables formales para cada política.
- Establecer revisiones trimestrales de cumplimiento y actualización documental.

Responsable principal:

- Comité de Seguridad de la Información

Área de apoyo:

- Área de TI
- Responsable SGSI



Fecha compromiso:

- Mayo 2026

Comentarios:

- Se acordó mantener una mejora continua de las políticas conforme evolucionen los riesgos tecnológicos y regulatorios de la organización.

#### **4. Concientización y capacitación en seguridad**

Tema revisado:

- Revisión de estrategias para fortalecer la cultura organizacional de seguridad de la información.
- Análisis de riesgos asociados a errores humanos, ingeniería social y uso inadecuado de sistemas corporativos.
- Evaluación de necesidades de capacitación para personal administrativo, operativo y técnico.
- Revisión de buenas prácticas relacionadas con:
  - Manejo de información confidencial
  - Uso seguro de correo electrónico
  - Gestión de contraseñas
  - Identificación de phishing y malware
  - Uso adecuado de dispositivos corporativos

Hallazgos:

- Se identificó falta de capacitación periódica formal en temas de ciberseguridad.
- Algunos usuarios desconocen procedimientos de reporte de incidentes de seguridad.
- Existe riesgo elevado de ataques de phishing debido al factor humano.

Solución propuesta:

- Implementar programas anuales obligatorios de capacitación en seguridad de la información.
- Realizar simulaciones periódicas de phishing y campañas de concientización.
- Generar material visual y comunicados internos sobre buenas prácticas de seguridad.
- Establecer mecanismos formales para reporte inmediato de incidentes.

Responsable principal:

- Recursos Humanos

Área de apoyo:

- Área de TI
- Responsable SGSI

Fecha compromiso:

- Julio 2026

Comentarios:

- Se recomendó incluir indicadores de cumplimiento y evaluaciones posteriores a cada capacitación.

## 5. Revisión de infraestructura tecnológica y controles perimetrales

Tema revisado:

- Revisión del estado de la infraestructura tecnológica utilizada dentro del alcance del SGSI.
- Análisis de controles implementados sobre:
  - Firewall Fortinet
  - Switches Cisco y Fortinet
  - VPN Zscaler
  - Redes LAN/WiFi corporativas
- Verificación de segmentación de red entre áreas administrativas, R&D y entornos operativos (OT).
- Revisión de controles de acceso remoto y monitoreo de tráfico de red.

Hallazgos:

- Se identificó la necesidad de fortalecer la segmentación de red para reducir riesgos de movimiento lateral en caso de intrusión.
- Algunos equipos de red no contaban con documentación actualizada de configuraciones y respaldos recientes.
- Se detectó dependencia crítica de servicios remotos y plataformas en la nube para operación diaria.

Solución propuesta:

- Implementar revisiones periódicas de configuraciones de firewall y switches.
- Mantener respaldos automáticos de configuraciones de red.
- Fortalecer segmentación mediante VLANs entre áreas críticas.
- Validar actualización continua de firmware y políticas de hardening en dispositivos de infraestructura.

Responsable principal:

- Área de Infraestructura TI

Área de apoyo:

- Administrador de Red
- Responsable SGSI

Fecha compromiso:

- Junio 2026

Comentarios:

- Se acordó priorizar la protección de activos relacionados con servicios críticos de red y accesos remotos corporativos.

## **6. Seguimiento de cumplimiento normativo y continuidad operativa**

Tema revisado:

- Revisión del cumplimiento de lineamientos relacionados con ISO/IEC 27001:2022 y normas complementarias aplicables al SGSI.
- Verificación de controles asociados a continuidad operativa y recuperación ante desastres.
- Análisis de mecanismos de respaldo, disponibilidad de información y recuperación de servicios críticos.
- Revisión de cumplimiento documental de políticas, procedimientos y controles implementados dentro del SGSI.

Hallazgos:

- Se identificó la necesidad de fortalecer la documentación de pruebas de recuperación y continuidad operativa.
- Algunos controles implementados aún no cuentan con métricas formales de seguimiento y evaluación.
- Se detectó dependencia elevada de plataformas cloud y servicios externos para operación diaria.

Solución propuesta:

- Programar pruebas periódicas de restauración de respaldos y validación de recuperación operativa.
- Implementar métricas e indicadores para evaluar la efectividad de controles del SGSI.

- Mantener actualizada la documentación normativa y procedimientos asociados a continuidad del negocio.
- Realizar revisiones periódicas de cumplimiento sobre controles críticos y activos sensibles.

Responsable principal:

- Responsable SGSI

Área de apoyo:

- Área de TI
- Comité de Seguridad de la Información

Fecha compromiso:

- Julio 2026

Comentarios:

- Se acordó fortalecer el seguimiento documental y la evidencia de cumplimiento para futuras auditorías internas y externas relacionadas con seguridad de la información.

## **ACUERDOS GENERALES**

- Mantener reuniones trimestrales del Comité de Seguridad de la Información para seguimiento del SGSI y revisión de riesgos emergentes.
- Priorizar la protección de activos críticos relacionados con formulaciones, documentación técnica, ERP M3 y plataformas colaborativas Microsoft 365.
- Implementar controles de acceso basados en roles (RBAC) y autenticación multifactor (MFA) en todos los sistemas considerados críticos dentro del alcance del SGSI.
- Fortalecer las políticas de respaldo y recuperación ante desastres mediante pruebas periódicas de restauración y validación de integridad de la información.
- Reforzar la segmentación de red entre áreas corporativas, R&D y entornos operativos (OT) para minimizar riesgos de propagación lateral ante incidentes de seguridad.
- Establecer programas anuales obligatorios de capacitación y concientización en ciberseguridad para todo el personal con acceso a información corporativa.
- Mantener actualizadas las políticas funcionales, procedimientos y controles de seguridad conforme evolucionen los riesgos tecnológicos, regulatorios y operativos de la organización.

- Realizar auditorías periódicas sobre accesos, configuraciones de red, plataformas cloud y cumplimiento de controles definidos en el SGSI.
- Fortalecer la documentación y trazabilidad de incidentes, respaldos, cambios de configuración y revisiones de cumplimiento para futuras auditorías internas y externas.
- Dar seguimiento continuo a la implementación de mejoras identificadas durante las sesiones del Comité de Seguridad de la Información.

## CONSTANCIA

Se deja constancia de que los temas revisados durante la sesión fueron analizados conforme a los lineamientos establecidos para el Sistema de Gestión de Seguridad de la Información (SGSI) de ProAmpac Planta San Luis, acordando las acciones y responsables correspondientes para seguimiento y mejora continua.

## PRÓXIMA SESIÓN

Agosto 2026 — Revisión de avance de controles implementados, resultados de auditorías internas y seguimiento de riesgos críticos del SGSI.

## FIRMAS

| Nombre            | Área                       | Firma |
|-------------------|----------------------------|-------|
| Mario Paz         | Gerente de Operaciones     |       |
| Vicente Rodríguez | Responsable SGSI           |       |
| Alberto García    | Área de Infraestructura TI |       |
| Gabriel Cisneros  | Responsable de R&D         |       |



DEPARTAMENTO DE TECNOLOGÍAS DE LA  
INFORMACIÓN - SEGURIDAD INFORMATICA

Sistema de Gestión de Seguridad de la Información

# **SGSI BASADO EN ISO/IEC 27001:2022**

PROAMPAC PLANTA SAN LUIS POTOSÍ

# Sección 1: Identidad Organizacional

## ProAmpac

---

Líder global en empaques flexibles con más de 50 años de trayectoria.

La planta de San Luis Potosí es un centro clave de Investigación y Desarrollo, donde se generan fórmulas y procesos de alto valor competitivo.

### Misión

Generar valor a través de soluciones innovadoras de empaque, protegiendo la propiedad intelectual y garantizando la calidad en cada proceso.

### Visión

Ser referente mundial en empaques flexibles sustentables, con sistemas de información seguros que respalden la innovación continua.

### Valores Fundamentales

- **Integridad** – Ética y transparencia
- **Intensidad** – Compromiso con la excelencia
- **Involucramiento** – Participación activa
- **Impacto** – Resultados medibles



# Secciones 2 y 3: Marco Normativo y Fundamentos del SGSI

## Arquitectura Normativa (ISO)

**ISO/IEC 27001:2022** (Requisitos del sistema)

**ISO/IEC 27000** (Glosario oficial)

### Marco Normativo

#### Gestión y Controles

ISO 27002 (Buenas prácticas) e ISO 27005 (Gestión de Riesgos)

#### Seguridad en la Nube

ISO 27017 e ISO 27018 (Protección de PII en Microsoft 365, OneDrive y SharePoint)

#### Continuidad y Resiliencia

ISO 22301 e ISO 27031 (Continuidad operativa y respaldo ante desastres)

#### Operación Segura

ISO 27035 (Incidentes), ISO 27033-1 (Redes/Firewalls) e ISO 27040 (Almacenamiento)

## Glosario Técnico y Aplicación en Planta

### Activo de Información

Datos de valor para la empresa: ERP, diseños de empaques, know-how técnico, configuraciones de PLCs.

### Riesgo y Evaluación

Incertidumbre sobre los objetivos: pérdida de datos o interrupción de la línea de producción.

### Confidencialidad

Protección de patentes y diseños exclusivos de clientes.

### Integridad

Garantizar que las recetas de fabricación no se alteren erróneamente.

### Control de Acceso

Restricción a personas autorizadas: permisos en SharePoint, LAN/WiFi.

# Sección 4: Contexto de la Organización (Inventario de Activos)

## Activos Internos (Lo que gestionamos)

### Propiedad Intelectual y Procesos

- Fórmulas de R&D
- Hojas Técnicas de procesos
- TAMUs (guías visuales)
- Diseños de Empaque

### Sistemas Corporativos

- ERP Infor M3
- Nube Corporativa (OneDrive / SharePoint)

### Infraestructura y Redes

- Laptops DELL Latitude y PC Optiplex
- Switches CISCO Catalyst 9200L y FortiSwitch
- Firewalls Fortinet FortiGate (30E, 60E, 60F)
- Accesos cifrados (VPN Zscaler)

## Activos Externos (Lo que interacciona)

### Plataformas Gubernamentales y Normativas

- Sistemas del SAT
- IMSS
- Ventanilla Única
- Portales de ISO

### Ecosistema de Clientes y Proveedores

- Diseños proporcionados por clientes
- Contratos y acuerdos de confidencialidad
- Bases de datos de proveedores

### Servicios de Terceros

- Plataforma SAP
- Microsoft 365 externo
- Software de rastreo logístico
- RespalDOS externos

# Sección 5: Liderazgo y Políticas Funcionales del SGSI

**Compromiso de la Alta Dirección:** Brindar el conocimiento y la continuidad operativa del área de Investigación y Desarrollo (R&D).

## Gobernanza, Incidentes y Cultura

- **Cultura de Seguridad:** Capacitación y concientización obligatoria cada 12 meses
- **Gestión de Incidentes:** Registro, clasificación y atención obligatoria en menos de 24 horas
- **Clasificación:** Etiquetado obligatorio de toda información de R&D como "Confidencial"

## Gestión de Identidad y Control de Accesos

- **Autenticación Robusta:** MFA obligatorio para Microsoft 365, OneDrive, SharePoint y ERP M3
- **Higiene de Credenciales:** Cambio obligatorio de contraseñas cada 90 días
- **Acceso Remoto Seguro:** VPN Zscaler bajo políticas de Zero Trust

## Protección de Endpoints y Continuidad

- **Seguridad en Equipos:** Cifrado de disco BitLocker y bloqueo automático a los 5 minutos en Dell Latitude y PC Optiplex
- **Custodia de Datos:** Respaldos automatizados diarios con cifrado AES-256 y retención mínima de 90 días

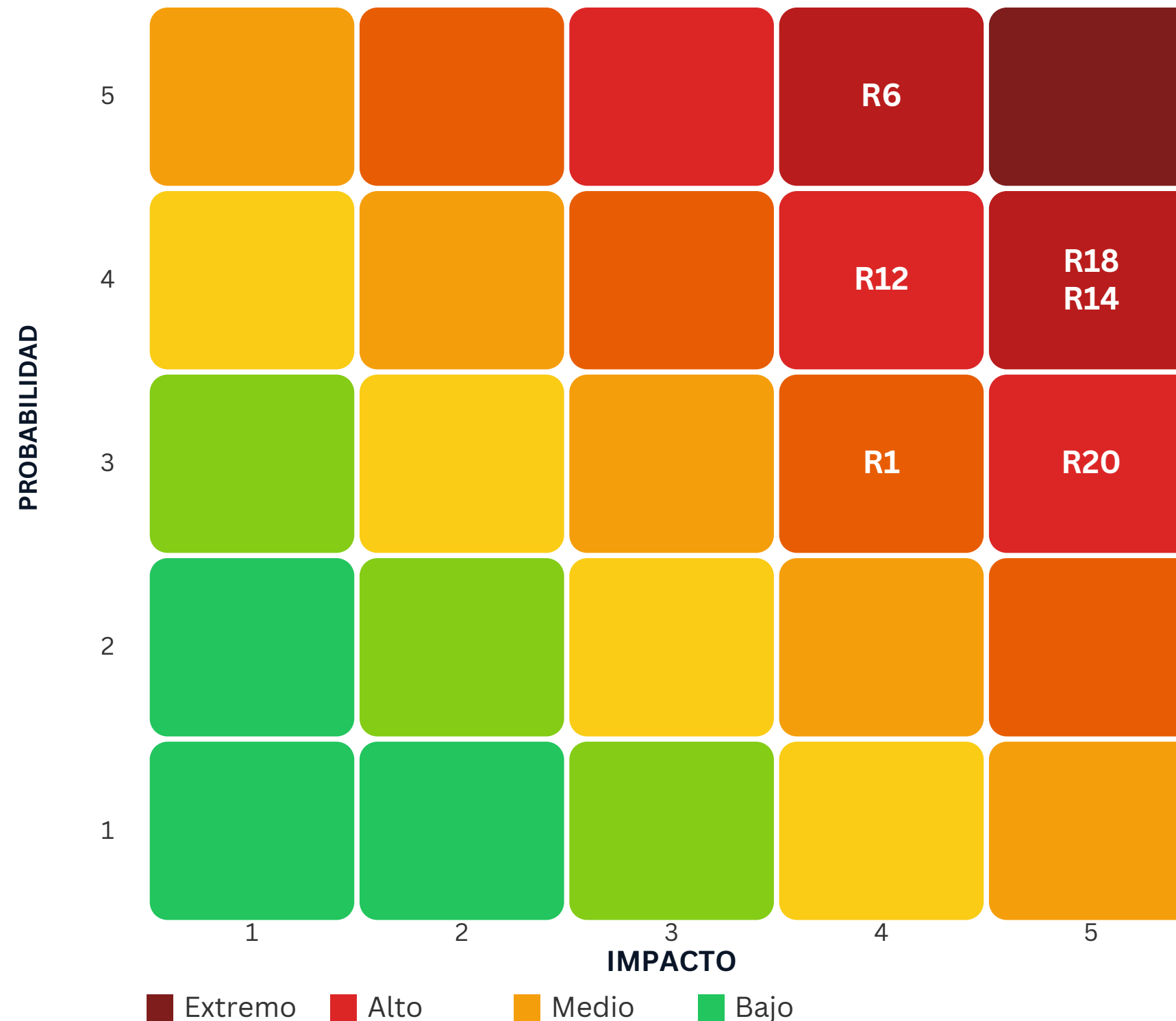
## Seguridad Perimetral e Infraestructura de Red

- **Firewalls FortiGate:** Regla estricta de "denegación por defecto" (default deny) y módulos IPS activos
- **Switches Cisco/Fortinet:** Segmentación mediante VLANs (R&D, OT/Planta, Corporativo) y seguridad de puertos (802.1X)

# Sección 6: Planificación y Matriz de Riesgos

Identificación, evaluación y mitigación de amenazas a la información crítica.

Matriz de Riesgos (Probabilidad vs. Impacto)



Riesgos Extremos

**R14:** Exposición o robo de fórmulas confidenciales  
Mitigación: **MFA + Cifrado**

**R6 / R18:** Ataques de Phishing y Acceso VPN Zscaler no autorizado  
Mitigación: **Limitación a equipos administrados + Filtros Antiphishing**

**R12:** Robo o pérdida de Laptops Latitude/Optiplex  
Mitigación: **Cifrado BitLocker obligatorio**

**R1 / R20:** Accesos no autorizados a sistemas críticos / Brechas de Firewall  
Mitigación: **RBAC + IPS en modo bloqueo**

## 8. Operación

### Gestión de acceso

**Estándar:** Definir y gestionar los accesos de todos los usuarios autorizados.

**Directriz:** Realizar auditorías periódicas de los permisos de acceso.

**Procedimiento:** Establecer un proceso para solicitar y aprobar nuevos accesos.

**Línea base:** Todos los usuarios deben cambiar sus contraseñas cada 90 días.

### 8.1 Fase Planeación

#### Objetivos:

- Definir controles de acceso para proteger los activos críticos del SGSI.
- Reducir riesgos relacionados con accesos no autorizados y uso indebido de credenciales.

#### Actividades:

- Identificar sistemas y usuarios dentro del alcance del SGSI.
- Definir roles, permisos y niveles de acceso.
- Establecer políticas de contraseñas seguras y MFA.

#### Riesgos considerados:

- Accesos no autorizados.
- Robo o uso indebido de credenciales.
- Privilegios excesivos.

#### Controles definidos:

- Control de acceso basado en roles (RBAC).
- Autenticación multifactor (MFA).
- Auditoría y monitoreo de accesos.

#### 8.1.1 Evidencia documental de controles administrativos

Como parte de la fase de planeación del ciclo PDCA, el área de IT proporcionó documentación corporativa relacionada con políticas de seguridad aplicables a la gestión de accesos, uso de dispositivos corporativos y protección de credenciales.

Estas políticas sirven como evidencia formal de la existencia de controles administrativos y operativos alineados con los objetivos del SGSI y los principios de confidencialidad, integridad y disponibilidad de la información.

La documentación proporcionada incluye:

- Política de uso y administración de celulares corporativos.
- Política de uso y administración de equipo de cómputo.
- Estándar corporativo de contraseñas (Passwords Standard).

**TRANSCONTINENTAL PACKAGING  
LATINOAMERICA**

| Política                 |                                                       |            |
|--------------------------|-------------------------------------------------------|------------|
| Nº LA-IT-PR-001          | Título: Política de uso y administración de Celulares | Versión 00 |
| Aseguramiento de Calidad |                                                       |            |

Pág. 1 de 4

### 1. OBJETIVO

Esta política define las reglas para el uso y condiciones en las que se otorga la herramienta de trabajo celular corporativo en TC Transcontinental.

### 2. ALCANCE

Todos los empleados de TC Transcontinental LATAM

### 3. DEFINICIONES

#### Malware

Un malware es un programa que se infiltra en los sistemas por medio de correos electrónicos, llaves USB, servicios en la nube (como DropBox) y otros medios digitales. Infecta archivos y aplicaciones que residen en sistemas de TI cuando se activa. Su objetivo principal es dañar cualquier sistema o destruir los datos a su alcance. También se puede propagar en cualquier lugar dentro de la organización o servir como plataforma para infectar entornos externos.

### 4. Contenido de la política

#### 1. Elegibilidad:

Son elegibles aquellos empleados cuya función requiera comunicación constante siempre y cuando esta necesidad sea plenamente justificada por el jefe inmediato.

#### 2. Uso:

El Teléfono celular al igual que el equipo de cómputo se considera una herramienta de trabajo por lo que su uso se restringe únicamente a actividades relacionadas con la empresa. El empleado es responsable por mantener el buen estado y la seguridad de este, lo cual incluye actualizar el dispositivo cuando así se le requiera y realizar los cambios regulares de claves. Cualquier falta relacionada con su uso puede estar sujeta a acciones disciplinarias descritas en nuestro código de conducta.

#### Otras consideraciones:

- Está prohibido instalar software no estándar. La excepción respaldada por una justificación comercial debe ser aprobada por el gerente del empleado.
- Su contenido, concretamente los datos almacenados, son y siguen siendo propiedad de TC Transcontinental.
- Solo el empleado autorizado puede hacer uso del celular corporativo TC Transcontinental; los miembros de sus familiares y amigos no pueden usarlo.
- El empleado es responsable por proteger el celular corporativo TC Transcontinental contra robos, pérdidas y daños.

Ilustración 11 POLÍTICA 1. LA-IT-PR-001



**TRANSCONTINENTAL PACKAGING  
LATINOAMERICA**

| Política                 |                                                               |            |
|--------------------------|---------------------------------------------------------------|------------|
| N° LA-IT-PR-002          |                                                               |            |
| Aseguramiento de Calidad | Título: Política de uso y administración de equipo de cómputo | Versión 00 |

Pág. 1 de 6

## 1. OBJETIVO

Esta política define las reglas para el uso de una estación de trabajo en TC Transcontinental. Las estaciones de trabajo también se designan con los términos: computadora, computadora portátil y tabletas.

## 2. ALCANCE

Todos los empleados de TC Transcontinental LATAM

## 3. DEFINICIONES

### Datos cifrados

Datos que se han procesado para hacer imposible la comprensión para cualquier persona que no tenga la clave o los medios para entregar datos como lo eran antes

### Ordenador

Una computadora es una máquina con una unidad central de procesamiento que le permite ejecutar programas de software independientemente del modelo de computadora o fabricante.

### Malware

Un malware es un programa que se infiltra en los sistemas por medio de correos electrónicos, llaves USB, servicios en la nube (como DropBox) y otros medios digitales. Infecta archivos y aplicaciones que residen en sistemas de IT cuando se activa. Su objetivo principal es dañar cualquier sistema o destruir los datos a su alcance. También se puede propagar en cualquier lugar dentro de la organización o servir como plataforma para infectar entornos externos.

### Firma

Una huella dejada por un malware que permite su reconocimiento y eliminación por mecanismos de defensa TC.

## 4. CONTENIDO DE LA POLITICA

### 4.1. Normas generales

- Todos los usuarios deben utilizar su propia cuenta para acceder a una estación de trabajo TC Transcontinental.
- Los usuarios no deben usar una cuenta con privilegios elevados para el uso diario (por ejemplo, derechos de administrador).

Ilustración 12 POLÍTICA 2. LA-IT-PR-002

## Passwords Standard

To: All IT employees

### 1. Purpose

This document sets out the standards to create passwords and is applicable to all regular and administrator users accounts. These standards must be applied on all the systems and applications where technology permits.

### 2. Definitions

Refer to the "Identity and Access Management Policy".

### 3. Rules

#### *General common*

The following rules apply to the passwords, regardless of the type of account associated:

- a) Must not be an acronym or a word from the dictionary.
- b) Must not contain information that identifies its owner, for example his/her name, nickname, the name of a family member, phone number, date of birth, etc.
- c) Must not be reused, that is, they must be different of the 6 previous passwords.
- d) Must contain characters from at least three of the following 4 sets when system permits:
  - i. Lowercase letters
  - ii. Uppercase letters
  - iii. Numbers
  - iv. Special characters (e.g.: ! »/\$%?&\*()\_+~)
- e) Must be kept secret, that is, they:
  - v. Must not be written.
  - vi. Must not be electronically stored in a unencrypted format.
  - vii. Must not be shared.
  - viii. Must not be forwarded to an IT manager or a resource from the service to partners for possible assistance. They do not need your password to provide assistance.

*Ilustración 13 Contraseñas Estándar*



## 8.2 Fase Acción

### Objetivos:

- Implementar los controles de acceso definidos en la fase de planeación.
- Garantizar el acceso seguro a sistemas y plataformas corporativas.

### Actividades:

- Configurar RBAC en ERP M3, SharePoint, OneDrive y VPN Zscaler.
- Implementar MFA y políticas de contraseñas seguras.
- Ejecutar procesos formales de alta, modificación y baja de usuarios.

### Riesgos controlados:

- Accesos indebidos a información confidencial.
- Compromiso de credenciales corporativas.
- Uso no autorizado de privilegios.

### Controles implementados:

- MFA obligatorio.
- Políticas de contraseñas corporativas.
- Monitoreo y registro de accesos.

## 8.3 Fase Verificación

### Objetivos:

- Verificar la efectividad de los controles de acceso implementados.
- Detectar desviaciones o incumplimientos relacionados con la gestión de accesos.

### Actividades:

- Auditar cuentas activas y permisos asignados.
- Revisar registros y bitácoras de acceso.
- Validar cumplimiento de políticas de MFA y contraseñas.

### Riesgos evaluados:

- Permanencia de accesos no autorizados.
- Permisos excesivos o cuentas inactivas.
- Fallas en controles de autenticación.

**Controles verificados:**

- Auditoría de accesos y permisos.
- Revisión de logs de autenticación.
- Monitoreo de accesos remotos y actividad sospechosa.

**8.3.1 Verificación documental de cumplimiento**

Durante la fase de verificación se realizó una revisión de las políticas corporativas proporcionadas por el área de IT, con el objetivo de validar que los controles administrativos y operativos definidos dentro del SGSI se encontraran alineados con las prácticas reales de seguridad implementadas en la organización.

La revisión permitió identificar controles relacionados con:

- Complejidad y expiración de contraseñas.
- Restricción de compartición de cuentas corporativas.
- Uso exclusivo de credenciales personales.
- Protección y bloqueo de estaciones de trabajo.
- Gestión segura de dispositivos corporativos.
- Restricciones de privilegios administrativos.
- Responsabilidad del usuario sobre activos tecnológicos.

Asimismo, se verificó que las políticas corporativas contemplaran lineamientos relacionados con autenticación segura, protección de información y control de accesos, evidenciando que el incidente analizado en la Sección 10 se originó por incumplimiento operativo de las políticas existentes y no por ausencia de controles documentados.

**8.4 Fase Actuación****Objetivos:**

- Implementar mejoras continuas en los controles de acceso del SGSI.
- Corregir desviaciones detectadas durante auditorías y revisiones de seguridad.

**Actividades:**

- Revocar accesos innecesarios y cuentas inactivas.
- Actualizar políticas y procedimientos de gestión de accesos.
- Implementar acciones correctivas derivadas de auditorías e incidentes.

**Riesgos tratados:**

- Reincidencia de accesos no autorizados.
- Vulnerabilidades en autenticación y permisos.

- Incumplimiento de políticas de seguridad.

**Acciones de mejora:**

- Fortalecimiento de controles RBAC y MFA.
- Ajuste de privilegios y permisos.
- Mejora continua del monitoreo y auditoría de accesos.

## 9. Evaluación de desempeño

| ID | Aspecto a Evaluar                                                 | Área             | Rol Responsable           | Responsabilidad Específica                                                 | Estado     | Observaciones                                                                           |
|----|-------------------------------------------------------------------|------------------|---------------------------|----------------------------------------------------------------------------|------------|-----------------------------------------------------------------------------------------|
| 1  | Política de Seguridad: ¿Es conocida y aplicada en la planta?      | Dirección        | Director General          | Asegurar que la política guíe las decisiones operativas.                   | Cumple     | Se confirmó que la política está publicada y es comprendida por los líderes de área.    |
| 2  | Inventario de Activos: ¿Se tiene control del hardware y software? | TI               | Administrador de IT Site  | Mantener actualizado el registro de laptops y servidores.                  | Cumple     | El inventario coincide con las existencias físicas de equipos Dell y Cisco.             |
| 3  | Uso Admisible: ¿El personal conoce las reglas de uso de equipos?  | TI               | Administrador de IT Site  | Difundir las normas de navegación y uso de herramientas.                   | En Proceso | Se detectó que falta reforzar la capacitación.                                          |
| 4  | Seguridad en RH: ¿Se evalúa al personal antes de contratar?       | Recursos Humanos | Coordinador de RH         | Validar antecedentes y referencias de nuevos ingresos.                     | Cumple     | Se verificó la aplicación de filtros de seguridad para personal de confianza.           |
| 5  | Término de Relación: ¿Se cortan los accesos al salir un empleado? | RH / TI          | Coord. RH / Adm. de IT    | Revocar permisos de red y recoger activos físicos.                         | Cumple     | El proceso de baja asegura la deshabilitación inmediata de cuentas en Active Directory. |
| 6  | Perímetro Físico: ¿Están protegidas las áreas críticas?           | EHS / Seguridad  | Jefe de Salud y Seguridad | Gestionar el acceso físico mediante tarjetas o bitácoras.                  | Cumple     | Las áreas de R & D y el Site cuentan con control de acceso funcional 24/7.              |
| 7  | Protección de Equipos: ¿Hay protección contra fallas eléctricas?  | Mantenimiento    | Jefe de Mantenimiento     | Supervisar el funcionamiento de UPS y plantas.                             | En Proceso | Se requiere una prueba de carga en la planta de emergencia del área administrativa.     |
| 8  | Control de Acceso: ¿Se revisan periódicamente los permisos?       | TI               | Administrador de IT Site  | Limitar el acceso a información según el principio de "mínimo privilegio". | Cumple     | Se realizó la depuración semestral de usuarios en el ERP y carpetas de red.             |
| 9  | Autenticación: ¿Se utiliza doble factor (MFA) en accesos remotos? | TI               | Administrador de IT Site  | Implementar y validar el uso de MFA en VPN y servicios nube.               | Cumple     | El acceso mediante Zscaler requiere validación obligatoria por dispositivo móvil.       |

|    |                                                                      |                  |                             |                                                              |            |                                                                                   |
|----|----------------------------------------------------------------------|------------------|-----------------------------|--------------------------------------------------------------|------------|-----------------------------------------------------------------------------------|
| 10 | Vulnerabilidades: ¿Se aplican parches de seguridad a tiempo?         | TI               | Administrador de IT Site    | Monitorear y corregir fallos técnicos en la infraestructura. | En Proceso | Se identificaron servidores con actualizaciones pendientes de ciclo crítico.      |
| 11 | Seguridad en Redes: ¿Está segmentada la red de producción y oficina? | TI               | Administrador de IT Site    | Configurar firewalls para aislar el tráfico de R & D.        | Cumple     | Los Firewalls Fortinet mantienen reglas de filtrado activas y monitoreadas.       |
| 12 | Monitoreo: ¿Se detectan intentos de intrusión o anomalías?           | TI               | Administrador de IT Site    | Analizar los logs de seguridad para detectar amenazas.       | Cumple     | El sistema de alertas reportó bloqueos preventivos de IPs sospechosas este mes.   |
| 13 | Propiedad Intelectual: ¿Se protegen las fórmulas y diseños?          | Calidad / R&D    | Coordinador de Calidad      | Resguardar la confidencialidad de los procesos de empaque.   | Cumple     | La documentación crítica de R & D está cifrada y bajo acceso restringido.         |
| 14 | Continuidad: ¿Se han probado los respaldos de datos?                 | TI               | Administrador de IT Site    | Garantizar la recuperación ante desastres informáticos.      | Cumple     | La última prueba de restauración del servidor M3 fue exitosa (Tiempo: 4 horas).   |
| 15 | Incidentes: ¿Se reportan y analizan las fallas de seguridad?         | Mejora Continua  | Gte. Jr. de Mejora Continua | Documentar causas raíz y aplicar acciones correctivas.       | En Proceso | Se está trabajando en un nuevo formato de reporte rápido para planta.             |
| 16 | Cumplimiento Legal: ¿Se respeta la privacidad de los datos?          | Legal / RH       | Coordinador de RH           | Asegurar el cumplimiento de la LFPDPPP.                      | Cumple     | Los avisos de privacidad están actualizados y visibles en los puntos de acceso.   |
| 17 | Concientización: ¿El personal recibe charlas de ciberseguridad?      | Recursos Humanos | Coordinador de RH           | Programar capacitaciones sobre phishing y riesgos.           | Cumple     | El 95% del personal administrativo completó el curso anual de seguridad.          |
| 18 | Revisión por Dirección: ¿Se evalúan los resultados del SGSI?         | Operaciones      | Gerente de Operaciones      | Revisar el desempeño y asignar presupuesto de mejora.        | Cumple     | La gerencia aprobó la inversión para renovación de firewalls el próximo semestre. |

## 10. Mejora

### 10.1 Política vulnerada:

#### Gestión de acceso

**Estándar:** Definir y gestionar los accesos de todos los usuarios autorizados.

**Directriz:** Realizar auditorías periódicas de los permisos de acceso.

**Procedimiento:** Establecer un proceso para solicitar y aprobar nuevos accesos.

**Línea base:** Todos los usuarios deben cambiar sus contraseñas cada 90 días.

### 10.2 Riesgo asociado a la política

#### Accesos no autorizados a sistemas críticos

**Probabilidad:** Media

**Impacto:** Crítico (Exposición de información confidencial, alteración de datos y afectación operativa).

**Riesgo:** Alto

#### Impacto potencial

- Exposición de información confidencial
- Alteración de datos
- Uso indebido de privilegios
- Afectación operativa

#### Acción de mitigación definida

- Implementación de RBAC
- Autenticación multifactorial (MFA)
- Auditorías periódicas de privilegios
- Revocación inmediata de accesos no autorizados

### 10.3 Descripción de la amenaza materializada

Se presentó un incidente de seguridad relacionado con el uso indebido de credenciales corporativas dentro del área administrativa de la organización.

El incidente ocurrió cuando un colaborador solicitó a un compañero apoyo para enviar un archivo desde su estación de trabajo corporativa. Para facilitar la actividad, el propietario del equipo compartió sus credenciales de acceso y adicionalmente indicó que la contraseña se encontraba escrita en una nota adhesiva (post-it) debajo del escritorio.

Posteriormente, el colaborador utilizó la cuenta con privilegios elevados para acceder a sitios web restringidos y realizar actividades fuera del alcance autorizado para su perfil de usuario.

El incidente representó una vulneración directa a la política de gestión de accesos y comprometió la trazabilidad y control de identidad dentro del SGSI.

## 10.4 Análisis de los hechos

### ¿Qué ocurrió?

Un usuario corporativo compartió de forma indebida sus credenciales de acceso con otro colaborador, incumpliendo las políticas de seguridad establecidas por el SGSI.

El segundo usuario aprovechó los privilegios de la cuenta compartida para acceder a recursos y sitios restringidos que normalmente no estaban permitidos para su perfil.

Además, se detectó una mala práctica crítica al mantener la contraseña visible físicamente mediante una nota escrita en el área de trabajo.

### ¿Hubo consecuencias indeseables?

Sí. Se identificaron las siguientes consecuencias:

- Uso indebido de privilegios corporativos
- Pérdida de trazabilidad sobre las acciones realizadas
- Exposición potencial de información confidencial
- Riesgo de fuga de información corporativa
- Incumplimiento de políticas internas de seguridad
- Incremento del riesgo de accesos no autorizados a sistemas críticos

Aunque no se confirmó extracción de información sensible, el incidente evidenció debilidades en la cultura organizacional de seguridad y en el manejo de credenciales.

### Línea temporal del incidente

| Hora     | Evento                                           |
|----------|--------------------------------------------------|
| 08:10 AM | Usuario comparte acceso a su estación de trabajo |
| 08:15 AM | Credenciales son utilizadas por un tercero       |
| 09:05 AM | Se detecta navegación en sitios restringidos     |
| 09:20 AM | IT identifica actividad anómala en logs          |
| 09:35 AM | Se rastrea tráfico y actividad                   |



|          |                                         |
|----------|-----------------------------------------|
| 10:00 AM | Contraseña comprometida es restablecida |
| 10:20 AM | Se deshabilitan sesiones activas        |
| 11:00 AM | Se levanta acta administrativa          |
| 12:00 PM | Se inicia campaña de concientización    |

*Ilustración 14 Línea de Incidentes*

### **Causa raíz del suceso**

Tras el análisis del incidente se determinó que la causa raíz principal fue el incumplimiento de las buenas prácticas de seguridad relacionadas con la gestión de credenciales y control de accesos.

Las causas identificadas fueron:

- Compartición indebida de cuentas corporativas
- Falta de concientización sobre riesgos de seguridad
- Manejo inseguro de contraseñas
- Ausencia de supervisión inmediata del uso de privilegios
- Dependencia excesiva de controles técnicos sin reforzar controles humanos

### **Medidas adoptadas para eliminar causa raíz**

Con el objetivo de evitar reincidencias, se implementaron las siguientes acciones correctivas y preventivas:

- Restablecimiento inmediato de credenciales comprometidas
- Reforzamiento de políticas de contraseñas seguras
- Prohibición formal de compartir cuentas corporativas
- Implementación obligatoria de autenticación multifactor (MFA)
- Capacitación extraordinaria sobre gestión segura de credenciales
- Campaña interna de concientización en ciberseguridad
- Auditoría de privilegios y accesos activos
- Incremento del monitoreo de actividad sospechosa en cuentas privilegiadas

### **Evaluación de eficacia de medidas adoptadas**

Posterior a la implementación de las acciones correctivas, se realizó una revisión de los controles de acceso y monitoreo de cuentas corporativas.

Los resultados obtenidos fueron:

- No se detectaron nuevos incidentes relacionados con compartición de credenciales

- El personal completó satisfactoriamente la capacitación de concientización
- Se incrementó el uso de MFA en accesos críticos
- Se redujo la presencia de contraseñas visibles físicamente en estaciones de trabajo
- Mejoró el cumplimiento de auditorías de acceso y revisión de privilegios

Se concluyó que las medidas implementadas fueron efectivas para reducir el riesgo asociado a accesos no autorizados y fortalecer la cultura de seguridad dentro de la organización.

## 10.5 Campaña de prevención – Acceso no autorizado a sistemas críticos

### Recomendaciones de seguridad

- Crear contraseñas seguras siguiendo políticas corporativas
- No compartir credenciales bajo ninguna circunstancia
- No almacenar contraseñas visibles en el área de trabajo
- Cambiar contraseñas periódicamente cada 90 días
- Utilizar autenticación multifactorial (MFA)
- Reportar actividades sospechosas inmediatamente al área de IT
- No utilizar privilegios corporativos fuera del alcance autorizado
- Colaborar con auditorías y revisiones periódicas de accesos
- Mantener bloqueada la sesión al abandonar el equipo de trabajo

**ProAmpac**

**CAMPAÑA DE PREVENCIÓN**

**ACCESO NO AUTORIZADO**

**A SISTEMAS CRÍTICOS**

Recientemente se vulneró la política de acceso a sistemas críticos. Analizamos lo que pasó para fortalecer nuestros controles y evitar que vuelva a ocurrir. La seguridad de la información es responsabilidad de todos.

**¿QUÉ PASÓ?**  
Se detectó acceso no autorizado a sistemas críticos debido al incumplimiento de la política de control de accesos.

**¿QUÉ HICIMOS?**

- ✓ Investigamos el incidente y su causa raíz.
- ✓ Contuvimos el acceso no autorizado.
- ✓ Reforzamos controles y monitoreo.
- ✓ Actualizamos y comunicamos buenas prácticas.

**RECOMENDACIONES DE SEGURIDAD**  
Sigamos estas prácticas para proteger nuestras credenciales y sistemas.

- 01 Crear contraseñas seguras siguiendo políticas corporativas.
- 02 No compartir credenciales bajo ninguna circunstancia.
- 03 No almacenar contraseñas visibles en el área de trabajo.
- 04 Cambiar contraseñas periódicamente cada 90 días.
- 05 Utilizar autenticación multifactor (MFA).
- 06 Reportar actividades sospechosas inmediatamente al área de IT.
- 07 No utilizar privilegios corporativos fuera del alcance autorizado.
- 08 Colaborar con auditorías y revisiones periódicas de accesos.
- 09 Mantener bloqueada la sesión al abandonar el equipo de trabajo.

**PROTEGER TU CONTRASEÑA ES PROTEGER A PROAMPAC. PEQUEÑAS ACCIONES, GRANDES IMPACTOS.**

**NUESTRA INFORMACIÓN NUESTRO COMPROMISO NUESTRO FUTURO**

JUNTOS INNOVAMOS SOSTENIBLES

Si tienes dudas o detectas algo inusual, contacta al **área de IT** inmediatamente.

Ilustración 15 Banner de Campaña ProAmpac